

資訊安全工程師-初級能力鑑定

資訊安全技術概論



鑑定制度架構

專業及級等	建議報考對象	考試科目	評鑑方法
Level1 初級資訊安全工程師	建議符合下列任一項條件： - 大專或技職校院學生(含畢業生) - 具備資訊安全知識與能力，或對資訊安全有興趣者。 ※以資通訊相關科系大三以上學生應考為佳	1.資訊安全管理概論 2.資訊安全技術概論	電腦測驗 (單選)

通過及授證標準

- 每科100分，單科成績達到70分為合格
- 達70分之單科成績，可保留三年
- 一次報考同一級等的所有考科，平均達70分得視為及格，但單科成績不得低於60分。

初級考試評鑑內容-資訊安全技術概論

科目	評鑑主題	評鑑內容	知識點
科目二： 資訊安全 技術概論	1.網路與通訊安全	1-1.網路安全	- 常見網路攻擊手法之基本觀念 - 網路設備與網路通訊協定之基本觀念 - 防火牆之基本觀念
		1-2.通訊安全	
	2.作業系統與應用程式安全	2-1.作業系統安全	- 常見網路攻擊手法之基本觀念，如：勒索病毒、阻斷服務、SQL Injection、Phishing、CSRF、XSS等 - 網路設備與網路通訊協定之基本觀念 - 防火牆之基本觀念
		2-2.作業系統與應用程式 (含資料庫與網頁)攻擊手法	
		2-3.程式與開發安全	
	3.資安維運技術	3-1.惡意程式防護與弱點管理	- 常用漏洞掃描工具、惡意程式的認識及防範之基本觀念 - 資料庫安全備份機制、復原、銷毀之基本觀念 - 密碼儲存與保護之基本觀念 - 系統日誌管理與分析之基本觀念
		3-2.資料安全及備份管理	
		3-3.日誌管理	
	4.新興科技安全	4-1.雲端安全概論	- 雲端資訊系統安全管理之基本觀念 - 行動裝置防護之基本觀念 - 智慧製造及物聯網防護之基本觀念
		4-2.行動裝置安全概論	
		4-3.智慧製造及物聯網安全概論	

資訊安全技術概論考題方向

- ◆網路通訊安全
- ◆作業系統與應用程式安全
- ◆資安維運技術
- ◆新興科技安全

網路與通訊安全

網路安全

通訊安全

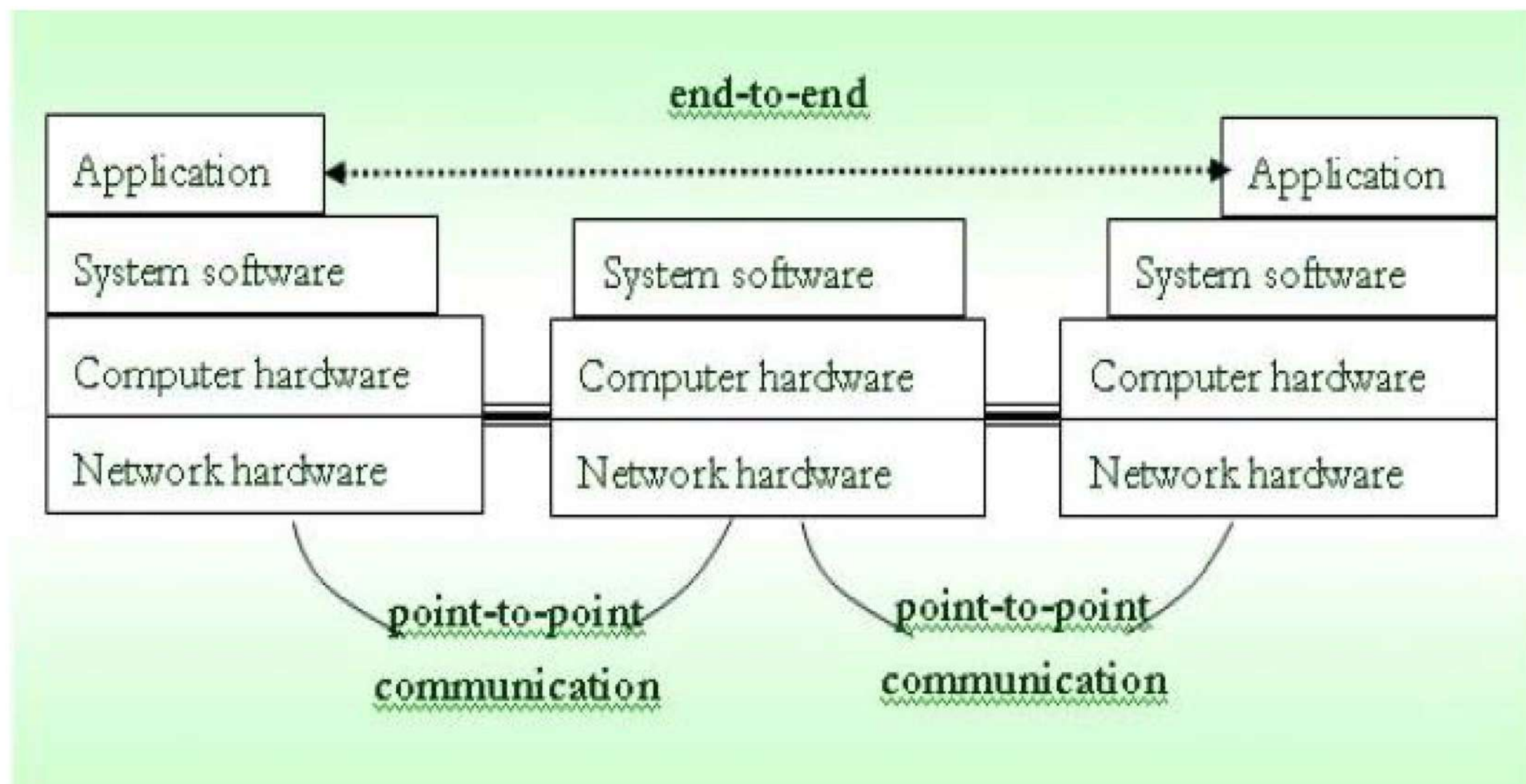
認識網路安全(network security)

- ◆ 定義：運用軟硬體技術來保護電腦網路與資料的機密性、完整性與可用性的規則與設定。有效的網路安全可以掌握網路的存取控制、針對網路的威脅進行防堵，並且防止其入侵後在網路中漫延。
- ◆ 範疇：網路安全涵蓋的範圍很廣，網路安全的類型包括存取控制、惡意程式防制、應用安全、入侵偵測、防止資料洩漏、電子郵件安全、行為數據分析、防火牆、虛擬私有網路(VPN)、無線網路安全、行動裝置安全、網路分隔、網頁安全、安全資訊與事件管理等。



建立網路的基本觀念

- ◆ 要了解網路的安全問題，必須先建立網路方面的基本知識，包括 ISO 的 OSI 網路模型，把複雜的網路分層描述。
- ◆ 層次化的觀念：

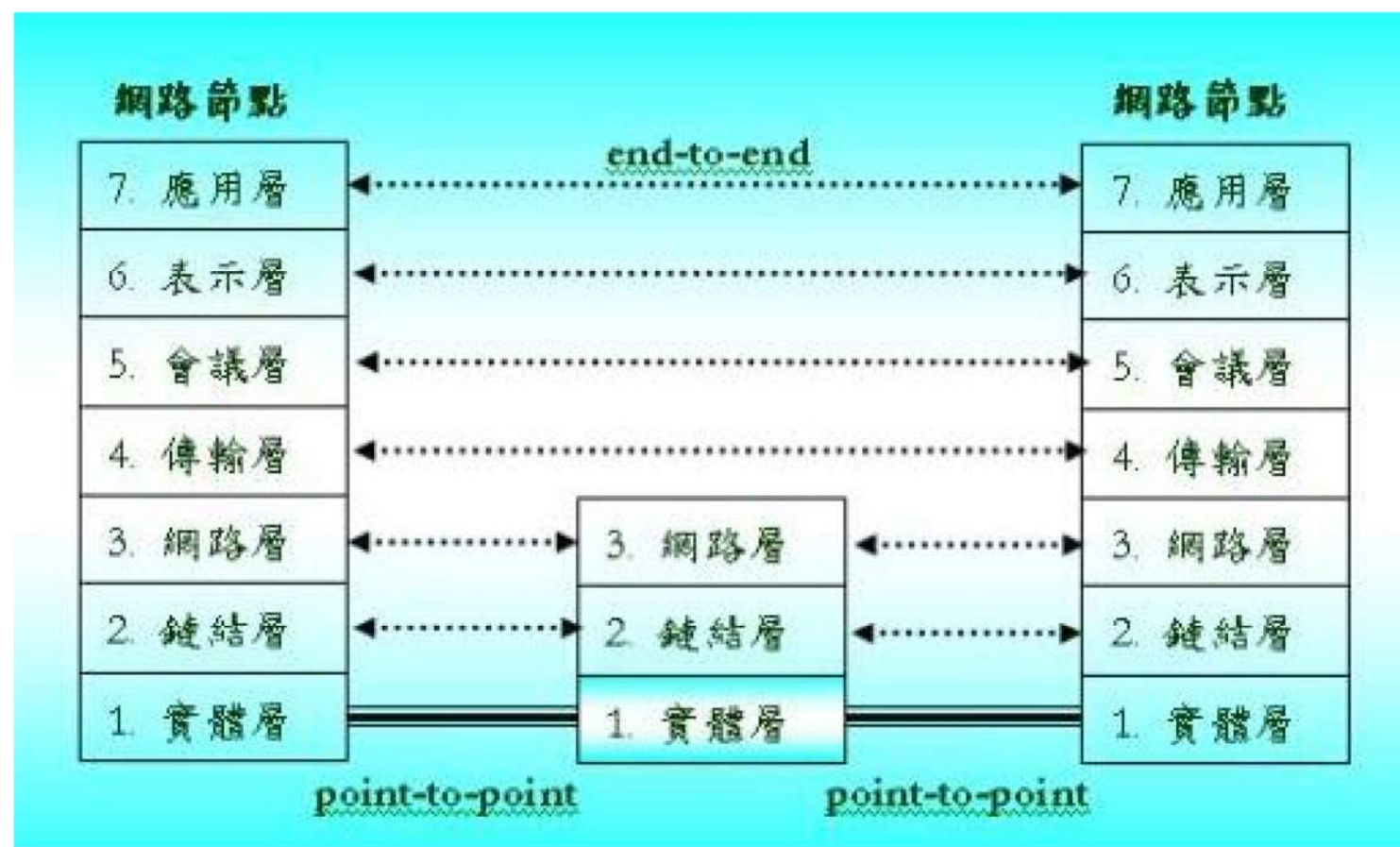


ISO / OSI 網路模型

- ◆ 通訊網路模型可以用來系統化地描述通訊網路的特性。由國際標準組織（ISO，International Standards Organization）於西元 1978 年所提出來的開放系統相連模型（OSI Model，Open Systems Interconnection Model），是有名的通訊網路參考模型。
- ◆ 採用多層的通訊架構可以達到分層負責和模組化的效果，也可以降低複雜度。
- ◆ ISO/OSI 參考模型最常用來描述多層的通訊架構，將通訊系統的功能分為 7 層，每層定義該層特有的協定。
- ◆ 每個協定提供該層特有的服務，並且只透過位於其下的協定與對方的相同協定交談，即對等式的通訊。
- ◆ 實際的資料仍要由上面的某一層依序一層層地傳至實體層，然後透過傳輸介質送到對方的實體層，再依序一層層傳至對應的上層。

ISO / OSI 網路模型的七層架構

- ◆ ISO / OSI 把網路模型分成七個層次，一到三層描述直接相連的網路節點之間的溝通法則，四到七層則說明間接相連的網路節點之間的協定。所謂的「網路節點」(Network Node) 包括電腦、終端機、網路終端設備等具有網路通訊能力的硬體系統。而溝通法則或是協定也泛稱為「網路協定」(Network Protocols)。
- ◆ 利用這種分層負責的方式，當某一層的技术發生變動時，其它層受到的影響比較小。



OSI 七層

Layer1 Physical Layer, PHY 實體層

定義了最基礎的網路**硬體標準**，包括各種網路線、各種無線連線方式，各種設備規範、以及各種接頭的規則，還有傳輸訊號的電壓等等。

Layer2 Data Link Layer 資料鏈結層

在這一層當中就制訂了 frame 的格式以及通過網路的方式。包括訊框的資料格式、錯誤控制、流量控制、檢查資料傳輸錯誤的方法等等，常聽到的MAC(media access control)即在此層。

應用層
Application Layer

展示層
Presentation Layer

會議層
Session Layer

傳輸層
Transport Layer

網路層
Network Layer

資料鏈結層
Data Link Layer

實體層
Physical Layer

OSI

OSI 七層

Layer3 Network Layer 網路層

IP(InternetProtocol)就是在這一層定義的，同時也定義出電腦之間的連線建立、終止與維持等，資料封包(packet)的傳輸路徑選擇等。這個層級當中最重要的除了 IP 之外，就是封包能否到達目的地的**路由(route)**概念

Layer4 Transport Layer 傳輸層

定義發送端與接收端的連線技術與封包格式，常見的有以下兩種：

- ◆ TransmissionControlProtocol，**TCP**，三向交握，具**可靠**性。
- ◆ UserDatagramProtocol，**UDP**，則為非可靠性。

應用層
Application Layer

展示層
Presentation Layer

會議層
Session Layer

傳輸層
Transport Layer

網路層
Network Layer

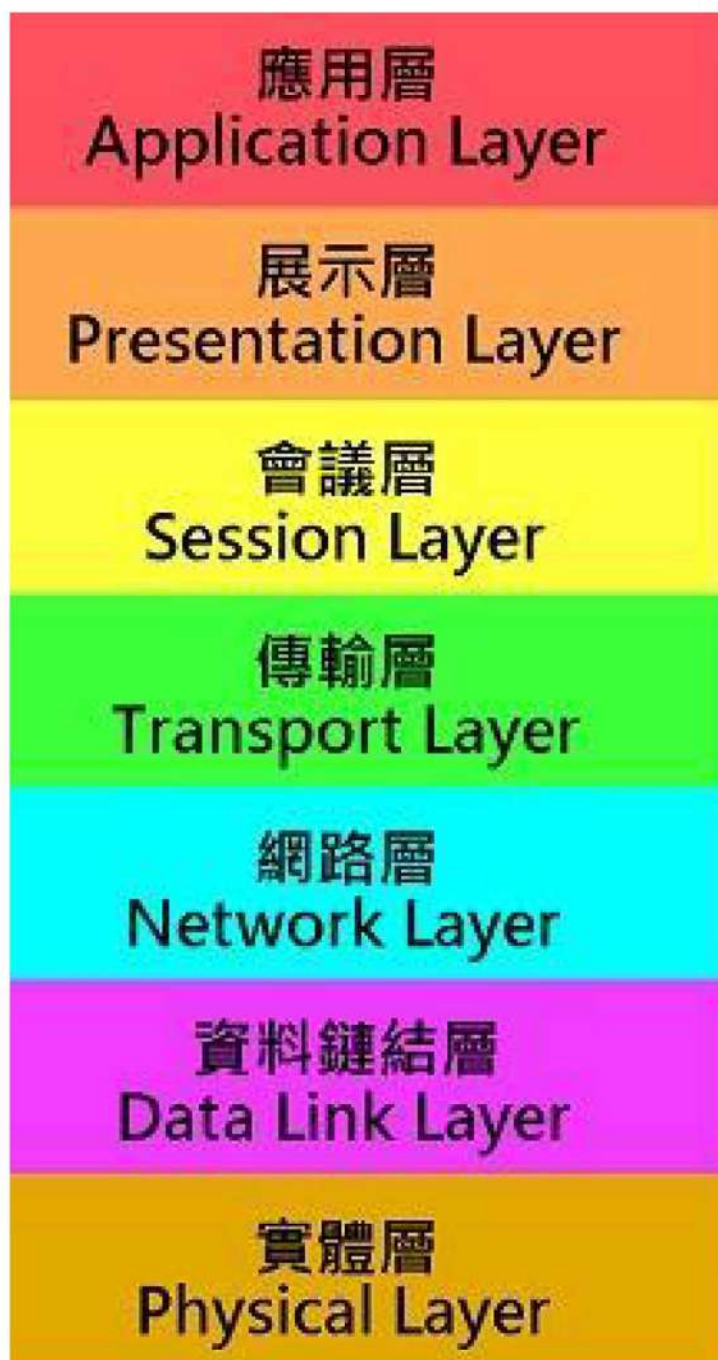
資料鏈結層
Data Link Layer

實體層
Physical Layer

OSI

OSI 七層

Layer5 Session Layer 會議層	定義了兩個位址之間的連線通道之連接與掛斷，負責在資料傳輸中設定和維護電腦網路中兩台電腦之間的通訊連接。
Layer6 Presentation Layer 展示/表現層	將來自本地端應用程式的資料格式轉換(或者是重新編碼)成為網路的標準格式。 在這個層級上面主要定義的是網路服務(或程式)之間的資料格式的轉換，包括資料的加解密也是在這個分層上面處理。
Layer7 Application Layer 應用層	與程式有關，提供為應用軟體而設的埠，以設定與另一應用軟體之間的通訊。 例如：HTTP，HTTPS，FTP，TELNET，SSH，SMTP，POP3 等

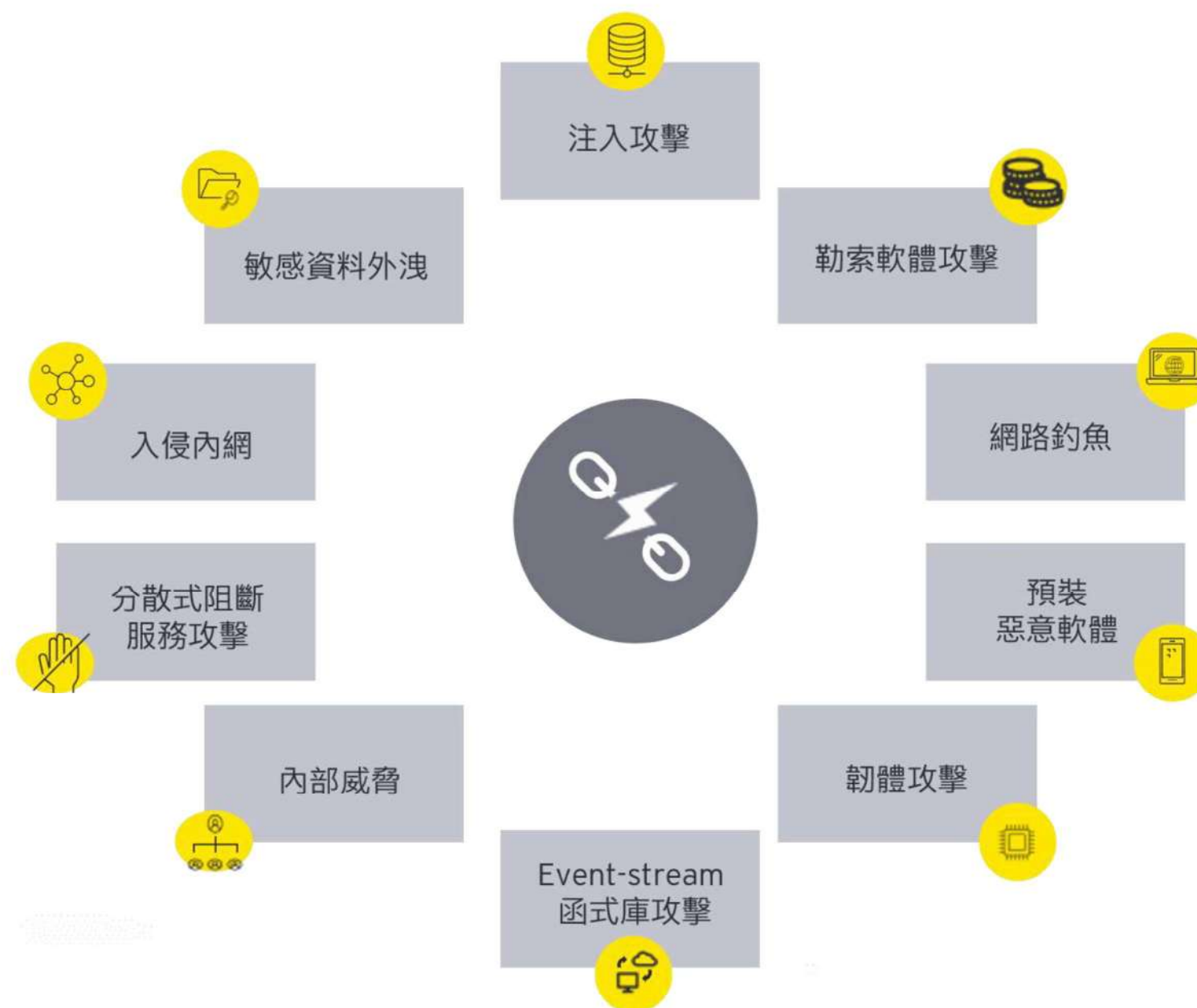


OSI

來自網路的攻擊與威脅

◆ 對於惡意程式來說，只要能到達受害的電腦，執行以後就能造成危害，不一定需要連上網路。

但是要進入受害的電腦，通常還是要透過網路。有很多入侵的方式則一定要經由網路來進行。



對網路各層次的攻擊手法

- ◆ **實體層**：線路搭接或私接網路或電話線路，成為非控管的隱匿通道，進行訊號的竊聽。
- ◆ **資料連結層**：封包監聽與 ARP Spoofing。利用工具搜集碰撞領域中的網路封包，可發起像 ARP Spoofing 的攻擊，監聽通訊。
- ◆ **網路層**：包括 Source Route、IP Spoofing、Smurf Attack、Ping of death 與 Teardrop。
- ◆ **會議層**：包括 SYN flood、DDos(distributed denial-of-service) 與 Session Hijacking。
- ◆ **應用層**：應用層的網路攻擊也很多種，包括 DNS poisoning、Brute force login、SQL Injection 與 Cross-Site Scripting。

通訊埠掃描(Port Scanning)

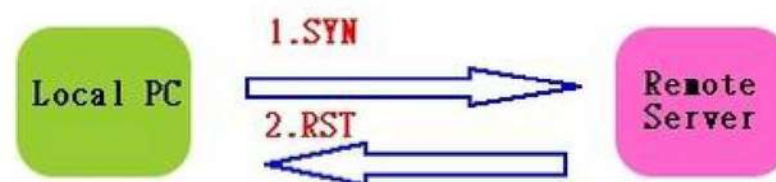
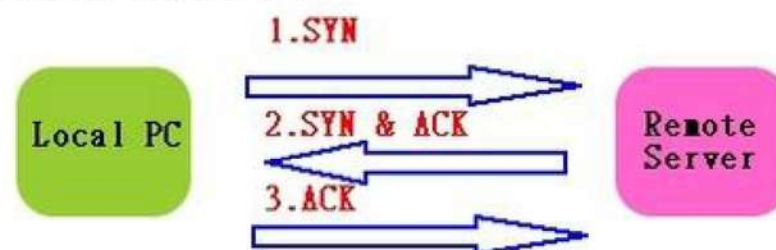
- ◆ 駭客可使用通訊埠掃描軟體(Port-Scanning Software) 來偵測攻擊目標的電腦有哪些通訊埠是開放的，

例如 DNS Server 的 port 53 可用來存取與攻擊 DNS 服務。

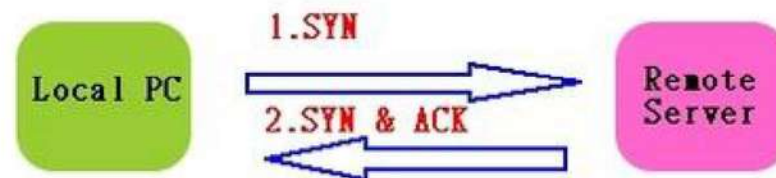
- ◆ 網路上有免費的通訊埠掃描軟體，例如 Nmap，網路管理者也可以使用這些軟體對所管理的伺服器進行掃描，

看是否有一些脆弱的開放通訊埠。

一、TCP Three-way Handshake



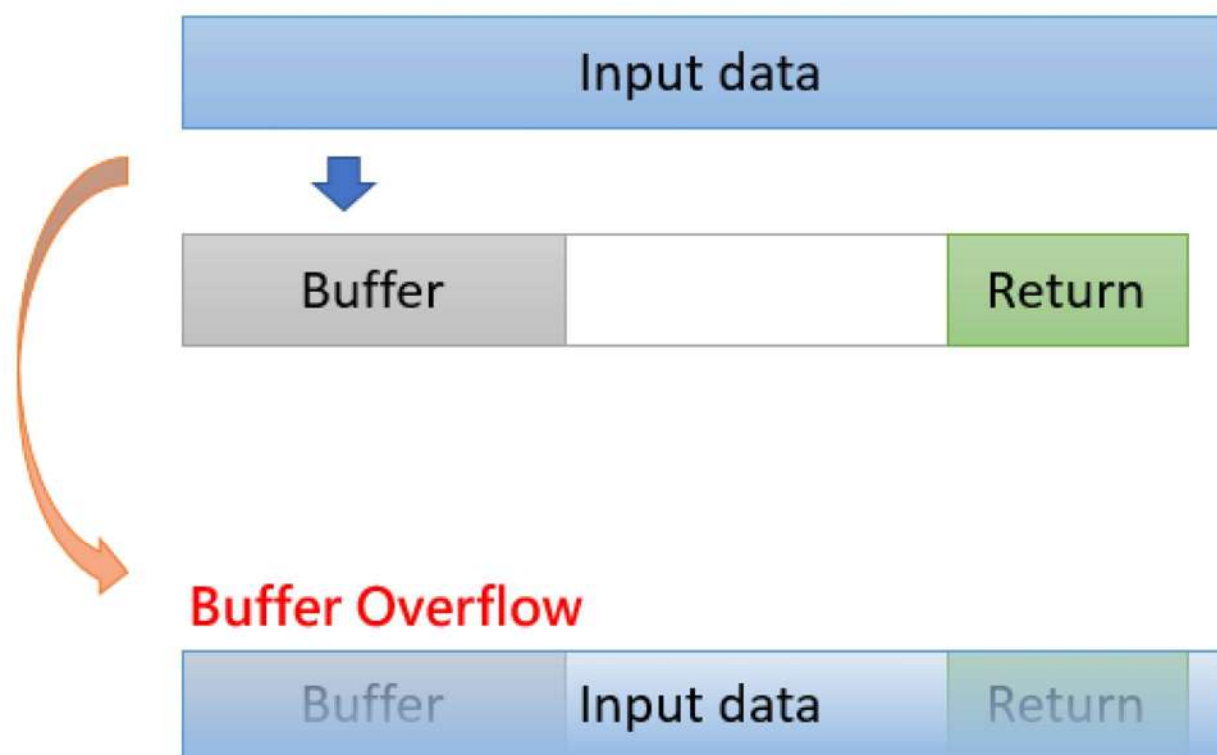
二、TCP SYN stealth



緩衝區溢位(Buffer Overflow) 攻擊

- ◆ 很多系統使用暫存作用的緩衝區來儲存一些資料，包括尚未用到的程式片段，這有可能是因為資料在交換時接收端來不及處理送過來的資料，必須先暫時儲存。
- ◆ 駭客運用暫存的狀況，讓接收資料的系統把惡意程式也寫入暫存區，未來誤以為是一般的程式而執行，很多病毒或蠕蟲程式是利用這種方式入侵。

特殊情況 (以stack為例)



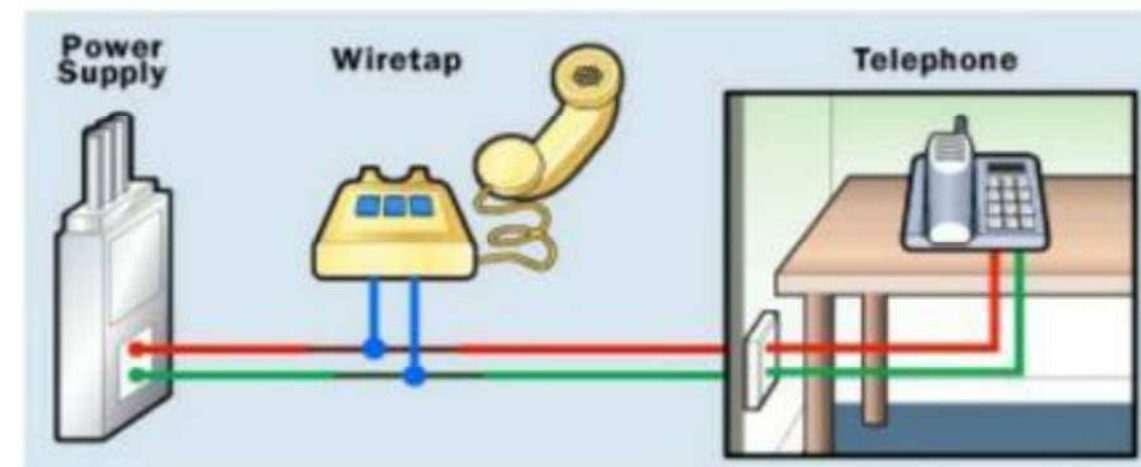
Buffer Overflow (以stack為例)



實體層攻擊- 線路搭接與線路私接

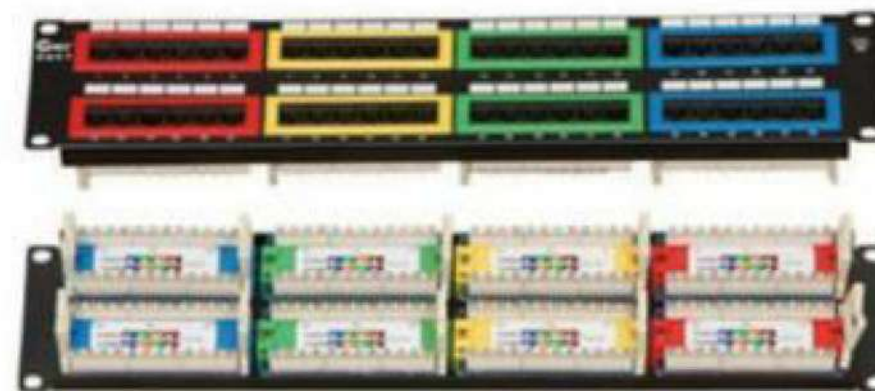
攻擊方式

- ◆ 搭接線路(網路與電話)進行訊號竊聽
- ◆ 私接線路變成隱匿通道(非控管中的線路)



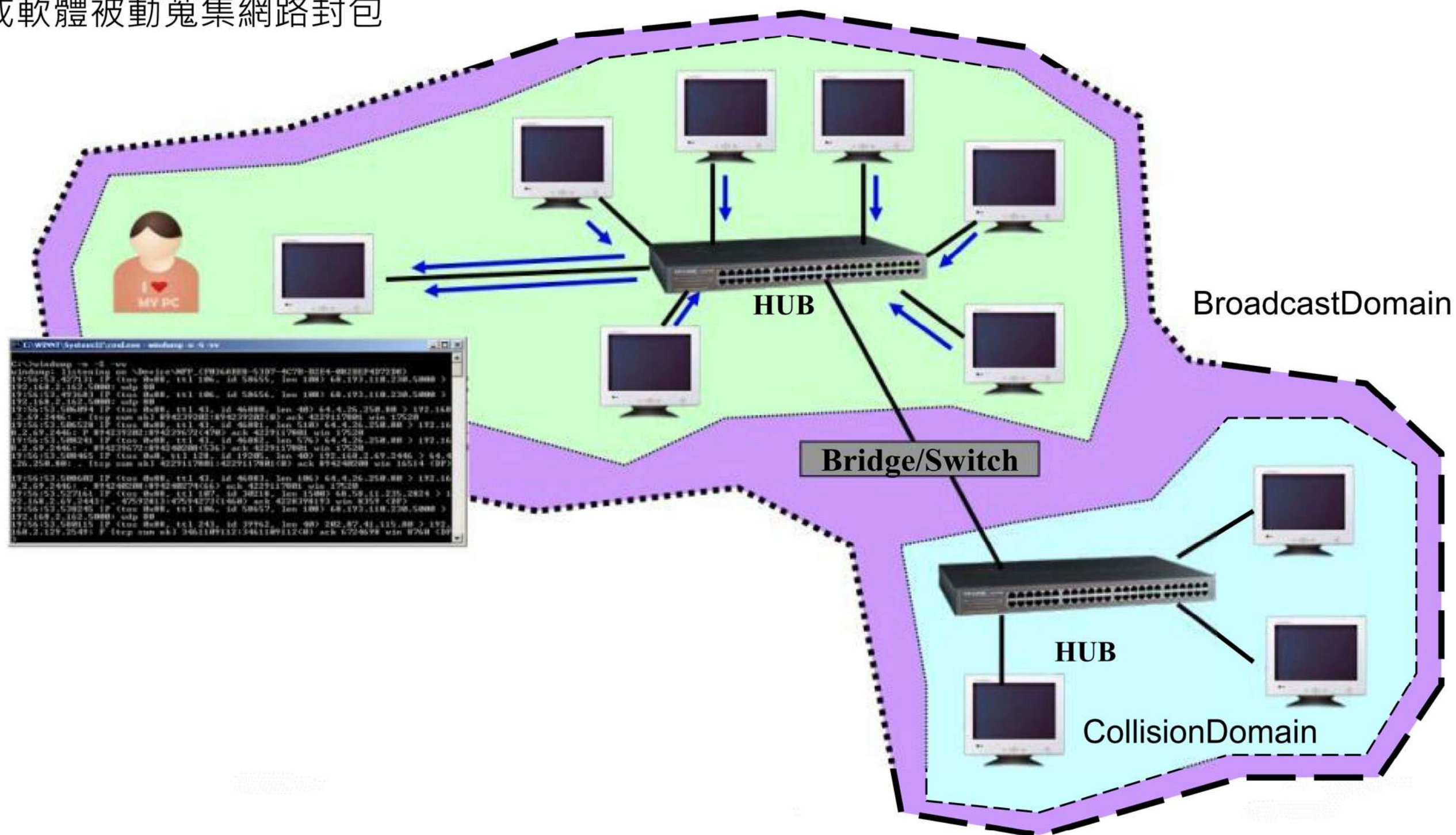
防護建議

- ◆ 定期的線路盤查
- ◆ 採用不同顏色區隔不同網段(安全區域)
- ◆ 機房、機櫃、線路室及管道間進行存取控管



資料鏈結層攻擊 - 封包監聽

- ◆ 透過工具或軟體被動蒐集網路封包



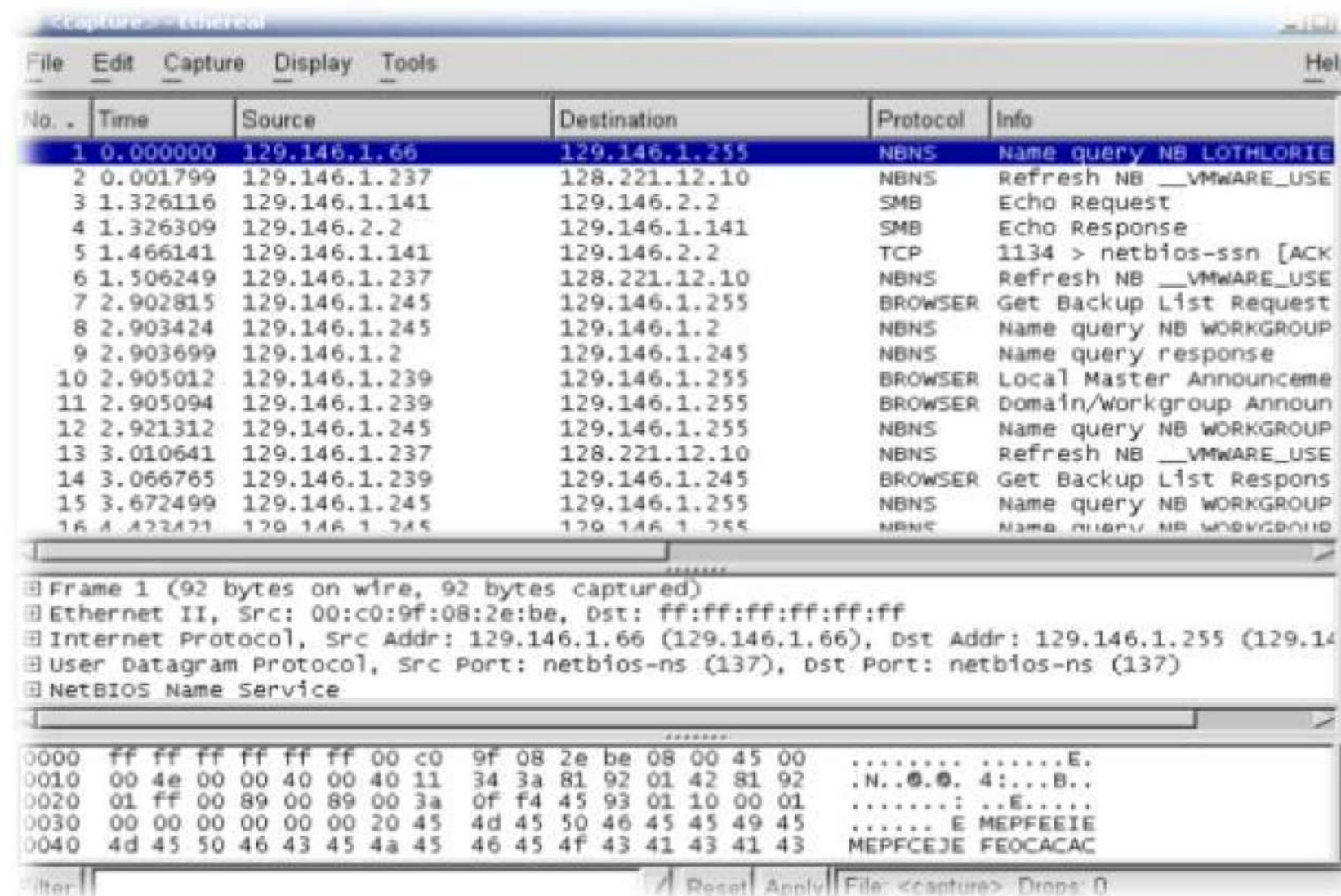
資料鏈結層攻擊 - 封包監聽

監聽工具

- ◆ Sniffer、MailSnarf、URLSnarf、WebSpy
- ◆ Tcpdump、Windump、Wireshark(Ethereal)
- ◆ Ettercap、NetIntercept

防護建議

- ◆ 採用加密連線
- ◆ 改用 Switch
- ◆ 網路線路的實體存取控制，避免搭接或私接問題



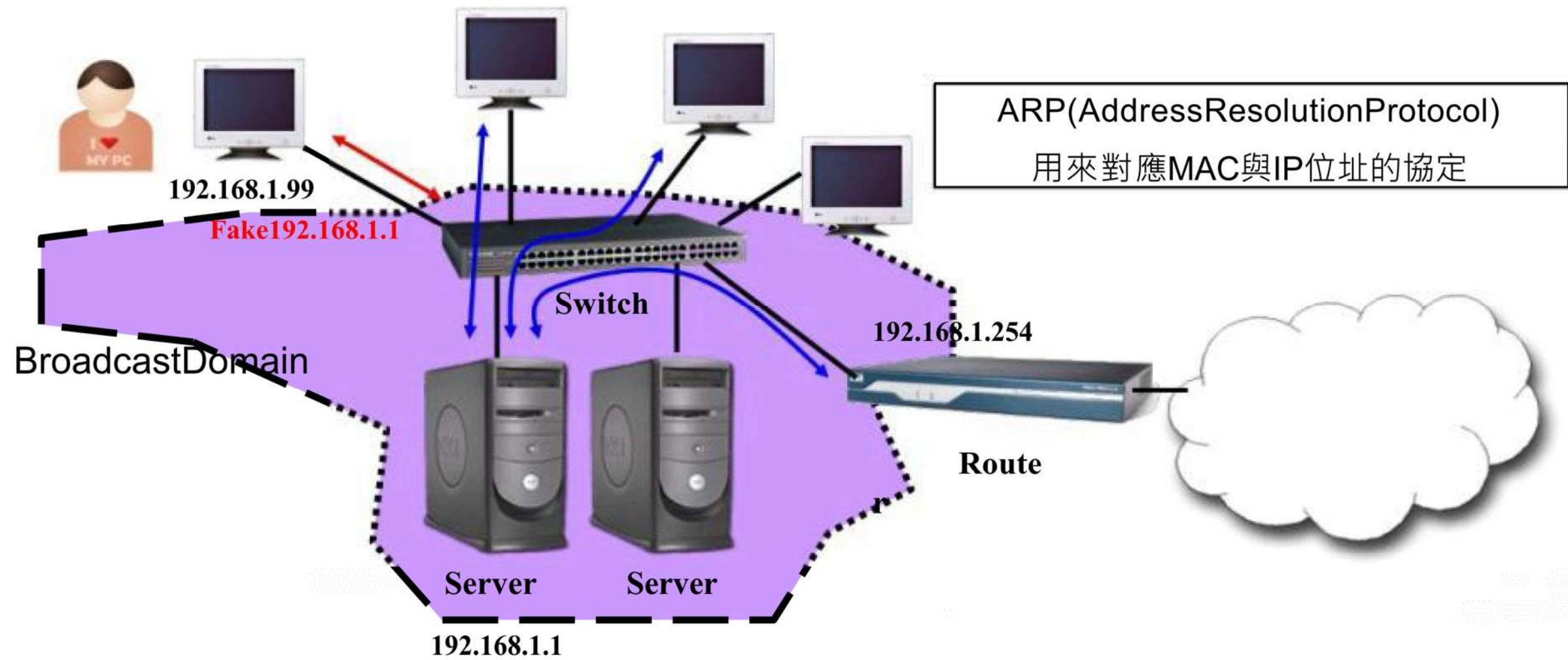
No.	Time	Source	Destination	Protocol	Info
1	0.000000	129.146.1.66	129.146.1.255	NBNS	Name query NB LOTHLORIE
2	0.001799	129.146.1.237	128.221.12.10	NBNS	Refresh NB __VMWARE_USE
3	1.326116	129.146.1.141	129.146.2.2	SMB	Echo Request
4	1.326309	129.146.2.2	129.146.1.141	SMB	Echo Response
5	1.466141	129.146.1.141	129.146.2.2	TCP	1134 > netbios-ssn [ACK
6	1.506249	129.146.1.237	128.221.12.10	NBNS	Refresh NB __VMWARE_USE
7	2.902815	129.146.1.245	129.146.1.255	BROWSER	Get Backup List Request
8	2.903424	129.146.1.245	129.146.1.2	NBNS	Name query NB WORKGROUP
9	2.903699	129.146.1.2	129.146.1.245	NBNS	Name query response
10	2.905012	129.146.1.239	129.146.1.255	BROWSER	Local Master Announceme
11	2.905094	129.146.1.239	129.146.1.255	BROWSER	Domain/workgroup Announ
12	2.921312	129.146.1.245	129.146.1.255	NBNS	Name query NB WORKGROUP
13	3.010641	129.146.1.237	128.221.12.10	NBNS	Refresh NB __VMWARE_USE
14	3.066765	129.146.1.239	129.146.1.245	BROWSER	Get Backup List Respons
15	3.672499	129.146.1.245	129.146.1.255	NBNS	Name query NB WORKGROUP
16	4.422421	129.146.1.245	129.146.1.255	NBNS	Name query NB WORKGROUP

Frame 1 (92 bytes on wire, 92 bytes captured)
Ethernet II, Src: 00:c0:9f:08:2e:be, Dst: ff:ff:ff:ff:ff:ff
Internet Protocol, Src Addr: 129.146.1.66 (129.146.1.66), Dst Addr: 129.146.1.255 (129.146.1.255)
User Datagram Protocol, Src Port: netbios-ns (137), Dst Port: netbios-ns (137)
NetBIOS Name Service

Offset	Hex	ASCII
0000	ff ff ff ff ff ff 00 c0 9f 08 2e be 08 00 45 00	E.
0010	00 4e 00 00 40 00 40 11 34 3a 81 92 01 42 81 92	.N..@. 4:...B..
0020	01 ff 00 89 00 89 00 3a 0f f4 45 93 01 10 00 01	:..E.....
0030	00 00 00 00 00 00 20 45 4d 45 50 46 45 45 49 45	E MEPFEEIE
0040	4d 45 50 46 43 45 4a 45 46 45 4f 43 41 43 41 43	MEPFCEJE FEOCACAC

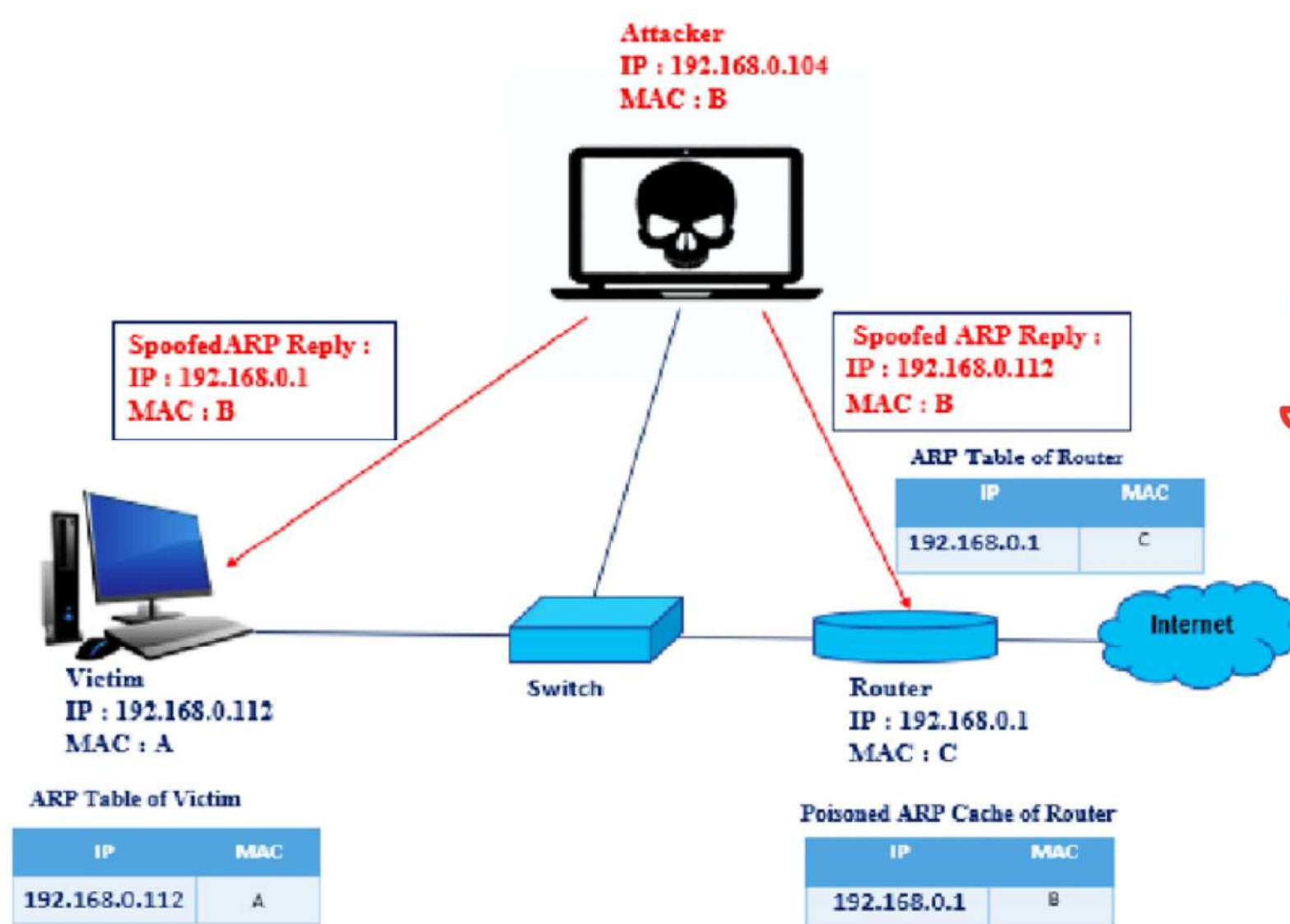
資料鏈結層攻擊 - ARP Spoofing

- ◆ 又稱為 ARP flooding、ARP poisoning 或 ARP Poison Routing。
- ◆ 在 Broadcast Domain 下無法被動監聽其他電腦間連線封包。
- ◆ ARP Spoofing 攻擊強迫偽冒其他 IP，讓攻擊者有機會監測到其他電腦間的通訊。

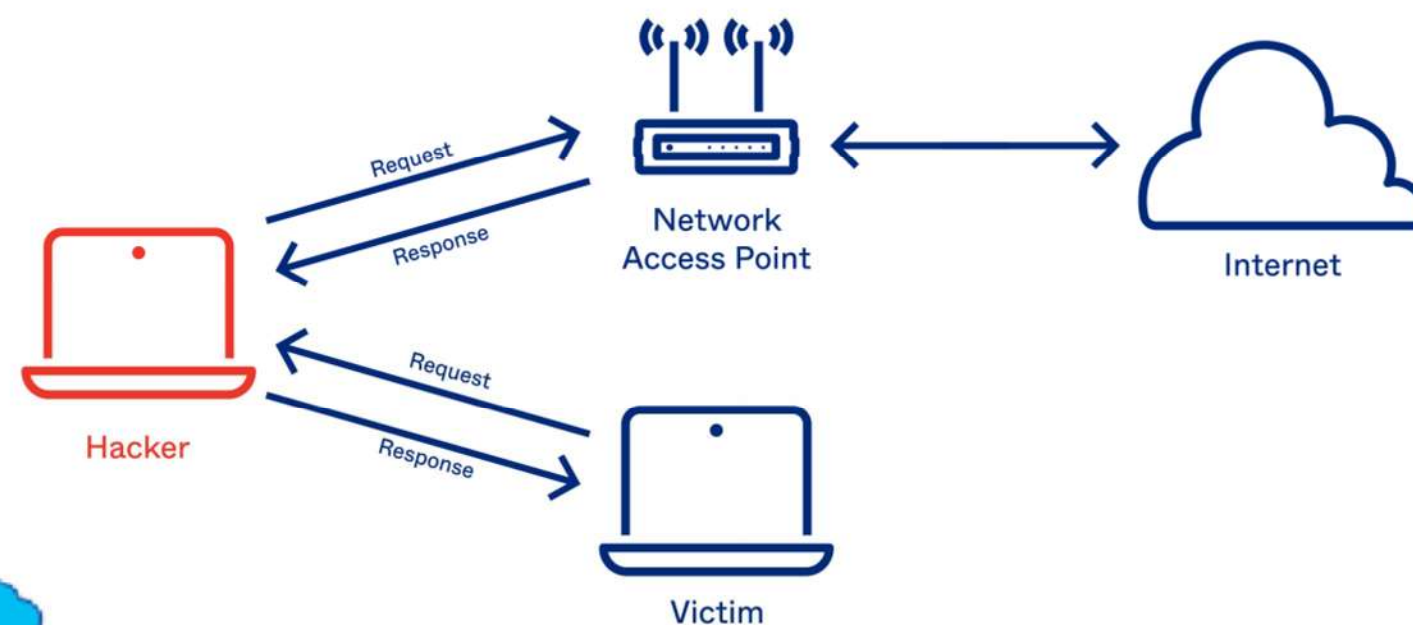


資料鏈結層攻擊 - ARP spoofing

- ◆ 攻擊者使用 ARP Broadcast 封包持續傳遞給其他電腦，告知 A 主機的 MAC 位址是攻擊者的 MAC 位址。
- ◆ 其他電腦要傳送 A 主機的封包因而會被送到攻擊者的主機上。攻擊者將封包錄下後再轉送到真正的 A 主機。



ARP Poisoning/Spoofing



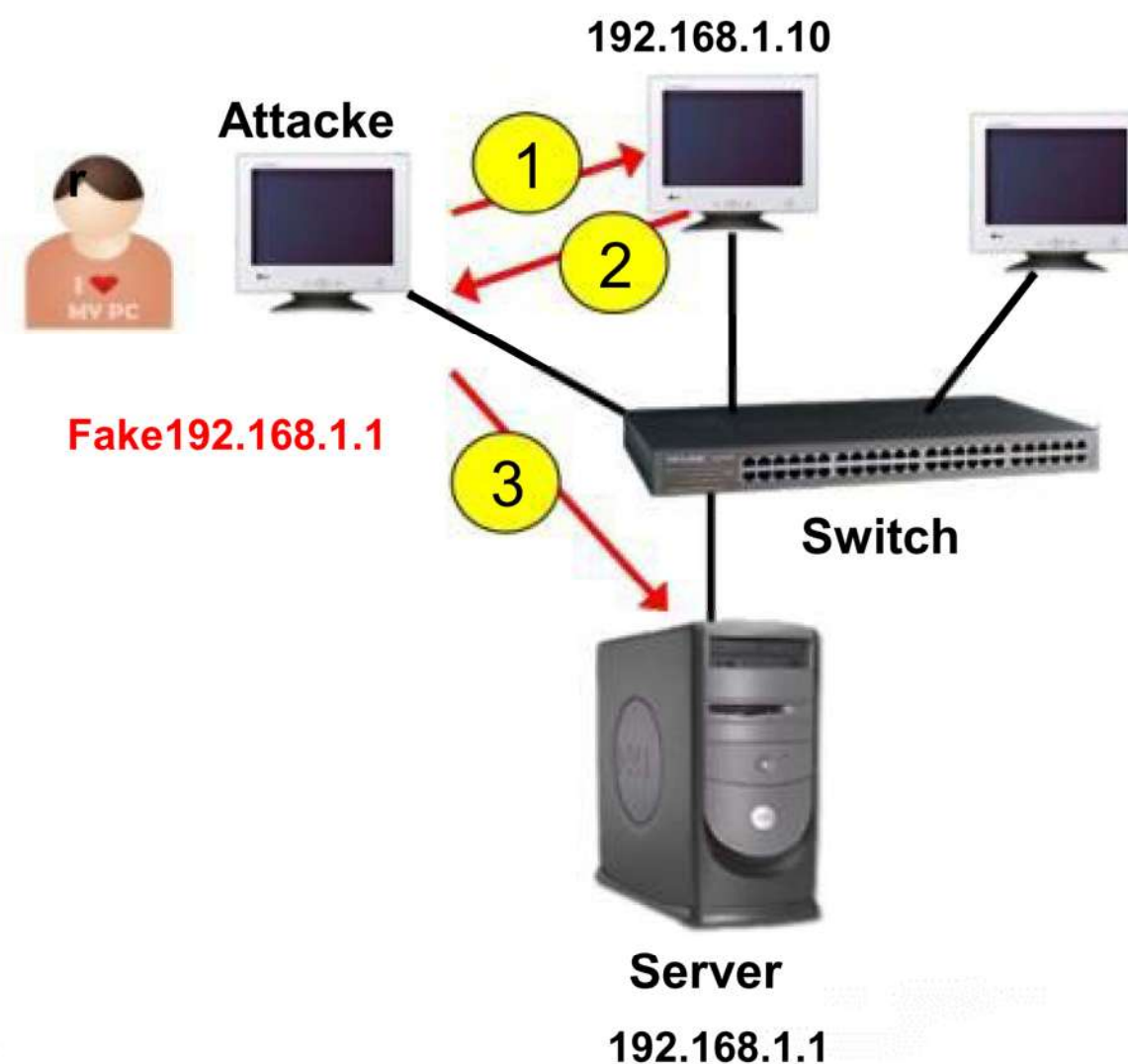
資料鏈結層攻擊 - ARP spoofing

攻擊手法

- ◆ 攻擊者使用 ARP Broadcast 封包告訴其他電腦，192.168.1.1 的 MAC 是 Attacker 的 MAC。
- ◆ 其他電腦要傳送給 192.168.1.1 的封包會被送到 Attacker。
- ◆ Attacker 將封包錄下後轉送到真正的 192.168.1.1。

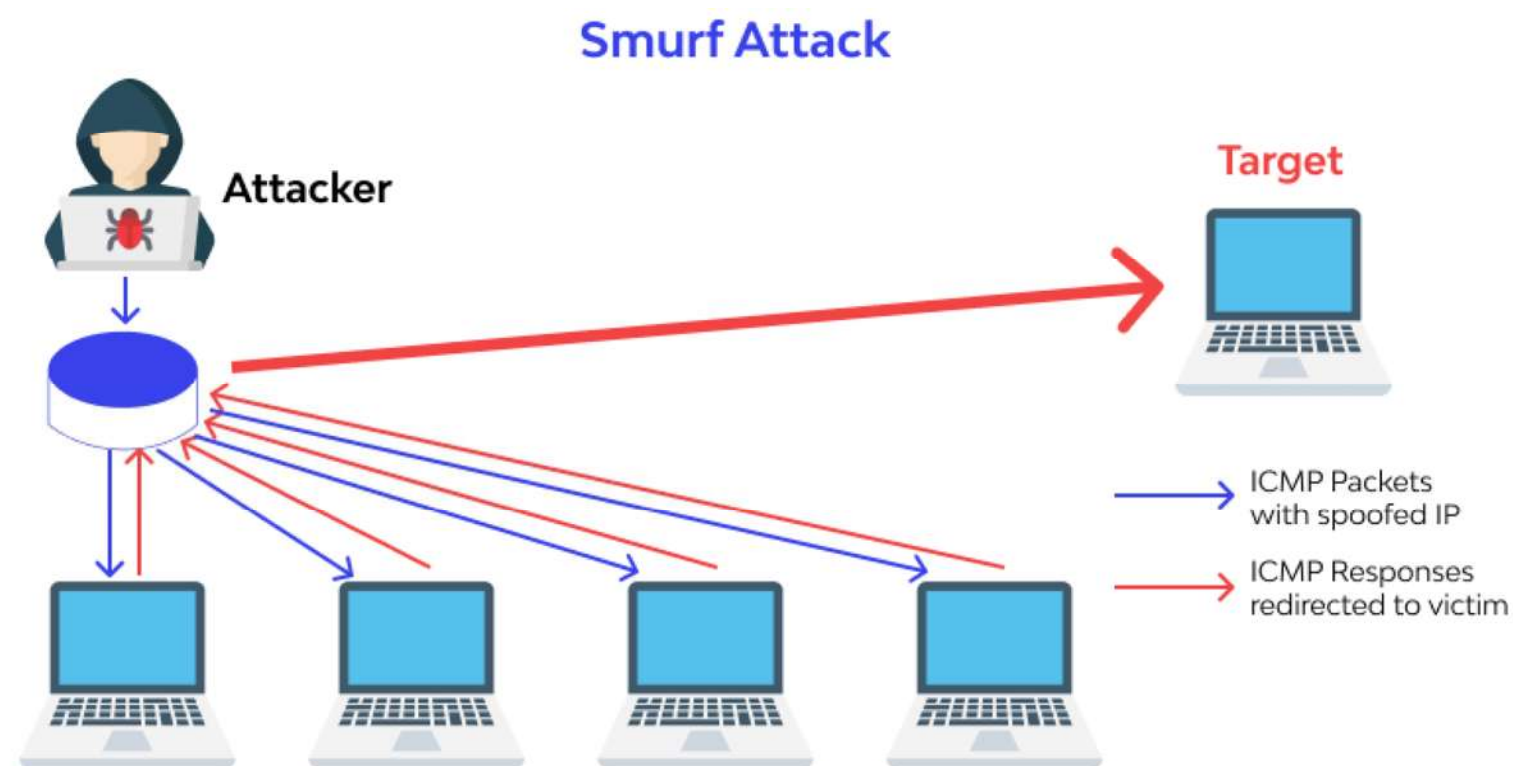
防護建議

- ◆ 強制使用靜態 ARP Table(小型網路)。
- ◆ 採用 VLAN 縮小 Broadcast Domain 的範圍。
- ◆ 啟用 Switch 中的 Port、MAC 及 IP 的對應控管。



網路層攻擊 - Smurf Attack

- ◆ 一種透過 Ping 封包塞爆受害者網路頻寬的阻斷服務攻擊，攻擊者偽冒受害者 IP 發送大量 Echo Request 給某特定網段的 Broadcast IP 位址（*.255或*.0）。
- ◆ 被攻擊網段所有電腦收到 Echo Request 封包之後，都回覆 Echo Reply 封包給受害主機，導致受害主機的網路頻寬被大量的 Echo Reply 封包占用。



網路層攻擊 - Smurf Attack

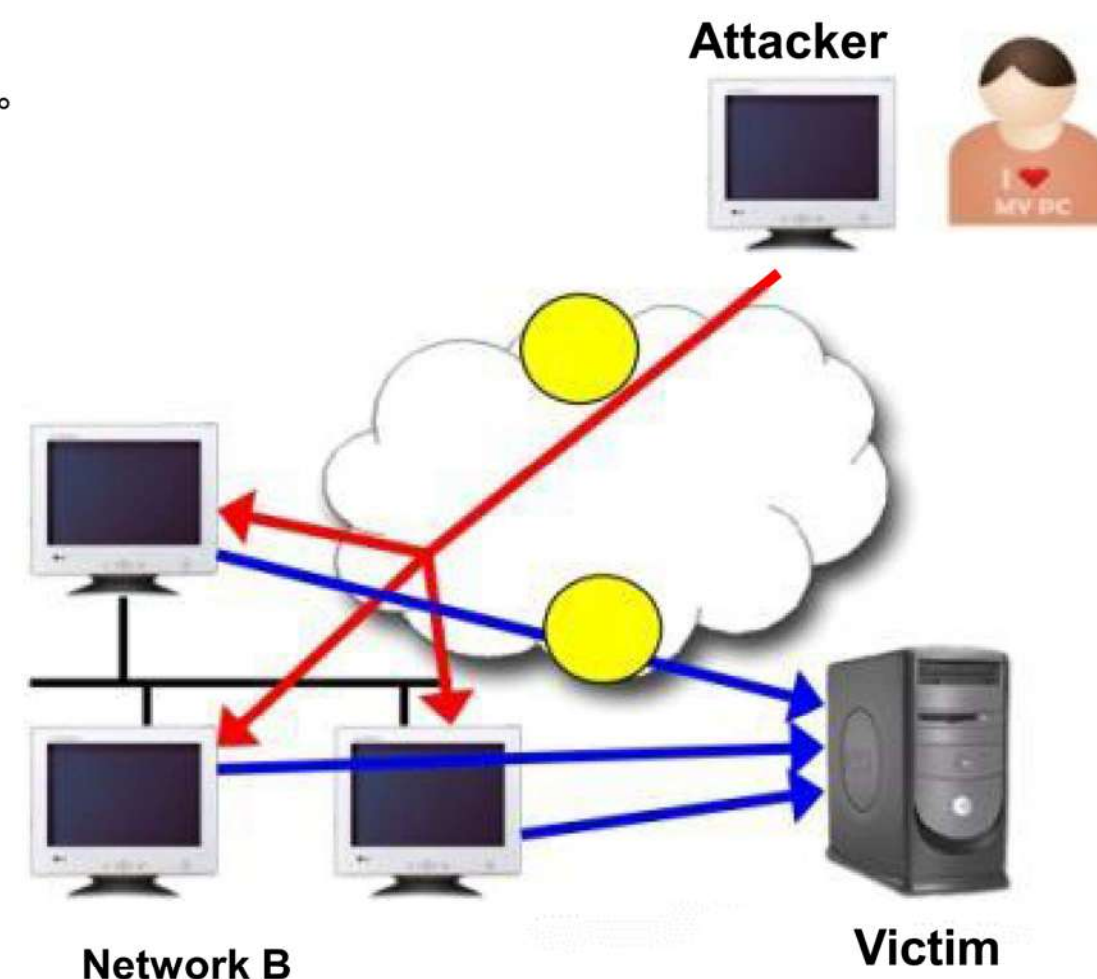
- ◆ 藉由 Ping 封包塞爆受害者網路頻寬的阻斷服務攻擊。

攻擊手法

- ◆ 攻擊者(Attacker) 偽冒受害者 IP(Victim) 發送大量 Echo Request 給 B 網段的 Broadcast IP 位址 (B.255或B.0)。
- ◆ B 網段所有電腦收到 Echo Request 封包，都回覆 Echo Reply 封包給 Victim。
- ◆ 導致 Victim 端頻寬被大量的 Echo Reply 封包所占用。

防護建議

- ◆ 在防火牆或路由器上阻擋 Network/Broadcast IP 的傳送。



網路層攻擊 - Ping of Death

- ◆ 屬於一種阻斷服務攻擊，只要一個 Ping 封包就讓作業系統當機。

攻擊手法

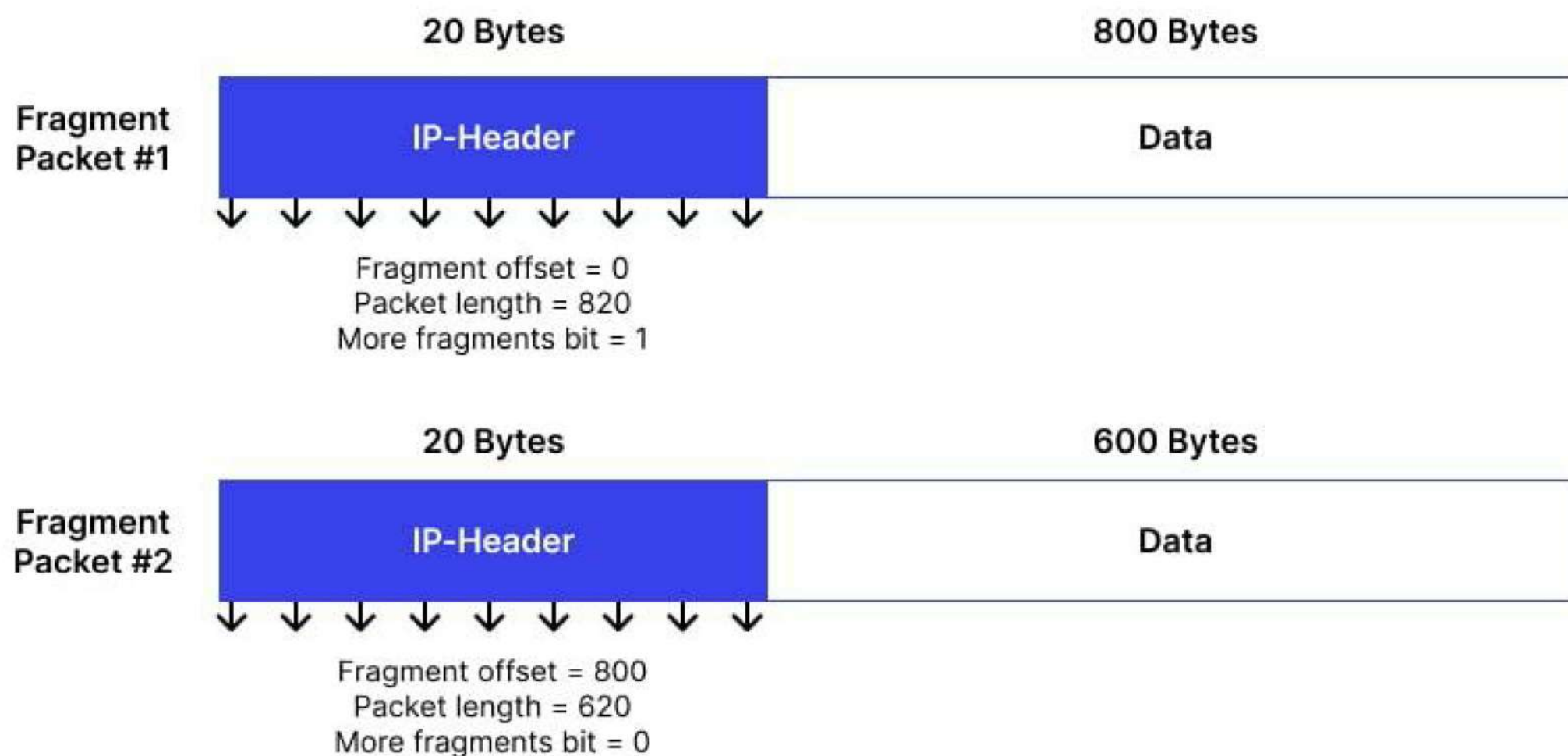
- ◆ 一般正常的 Ping 封包大小為 56 位元(含 IP 標頭為 84 位元)。
- ◆ 攻擊者故意傳送一個大小超過 65536 位元的 Ping 封包給受害者(IP協定允許封包大於 65536)。
- ◆ 受害作業系統無法處理大於 65536 位元的 Ping 封包，導致系統當機或重新開機。
- ◆ 攻擊者的來源 IP 經常是偽冒的 IP 位址。

防護建議

- ◆ 修補作業系統弱點(目前大部份作業系統都已修補這個弱點)。

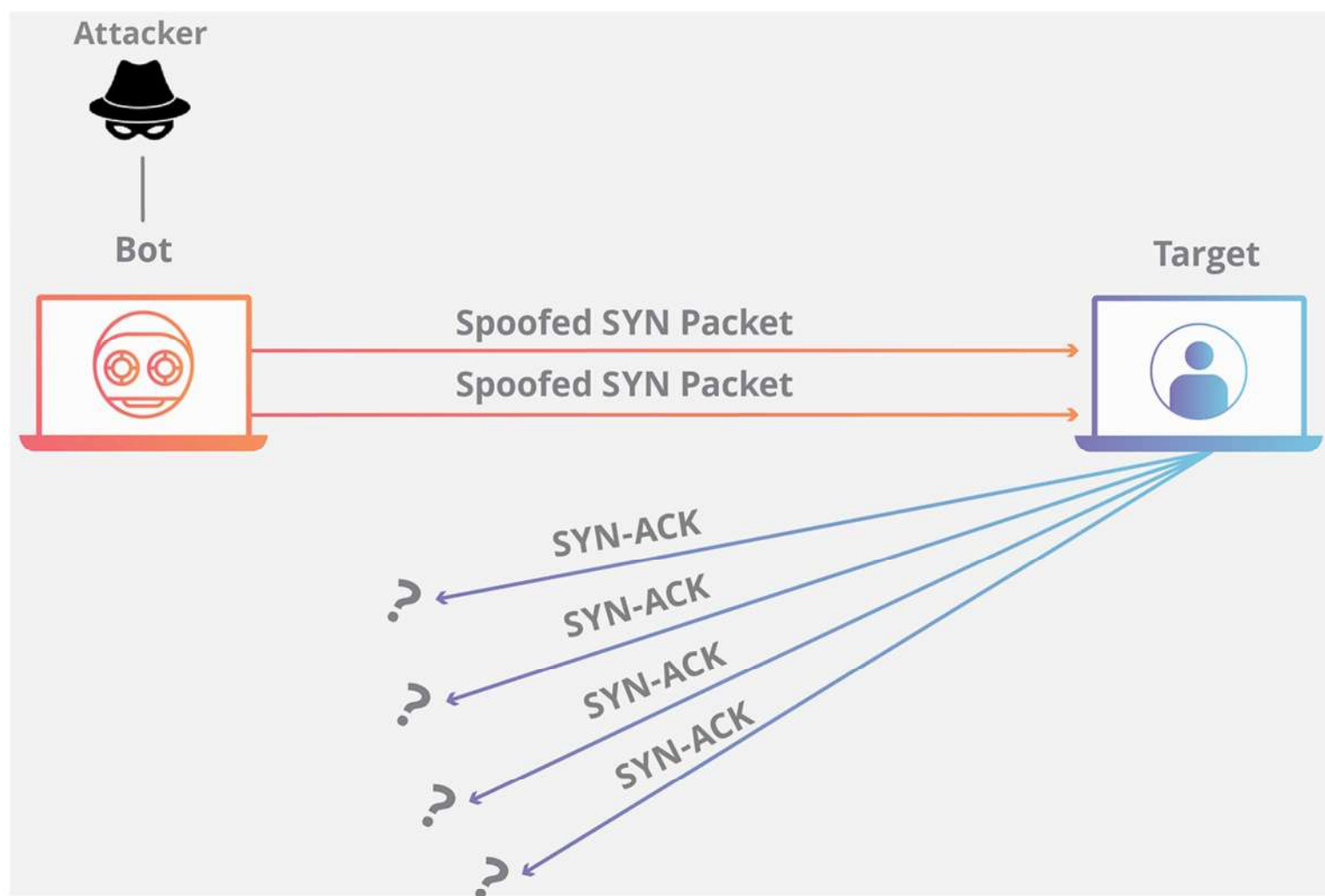
網路層攻擊 - Teardrop

- ◆ IP 封包太大時依 IP 協定可將封包進行切割(Fragment)，並在片段的封包中註記其偏移序號(offset)，以利接收端依偏移序號進行重組。
- ◆ 攻擊者刻意攪亂片段封包中的偏移序號(offset)，讓接收端作業系統在重組片段封包時產生錯誤，進而造成系統當機。



傳輸層攻擊 - SYN Flood

- ◆ 攻擊者傳送大量偽冒來源 IP 的「TCPSYN請求」封包給受害的伺服器。伺服器為每一個 TCP 連線請求分配系統記憶體資源，使系統連線資源被耗盡。
- ◆ 此攻擊使正常的連線無法建立，因持續收到大量惡意的 TCPSYN 封包，來源 IP 通常也是偽冒的，因此不易封鎖來源 IP 阻擋攻擊。



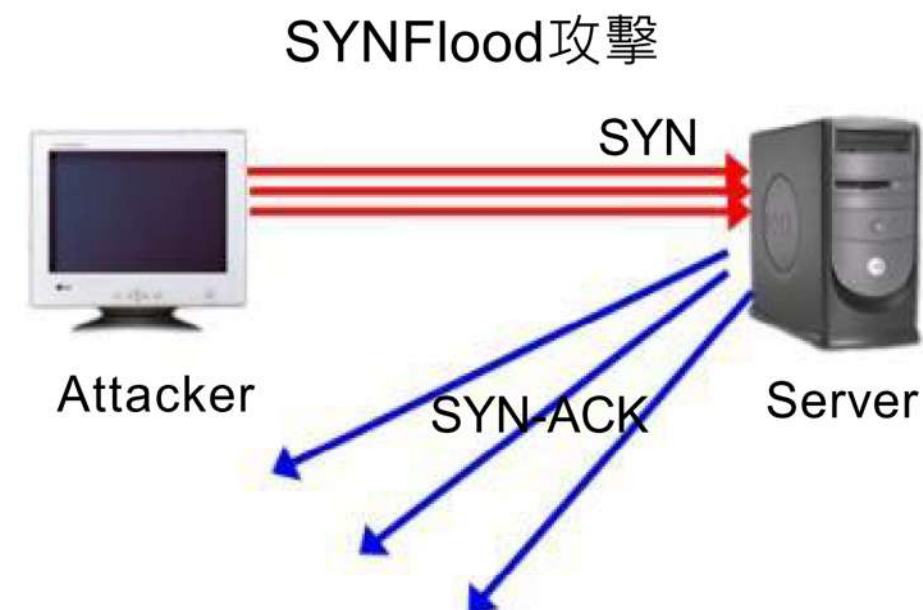
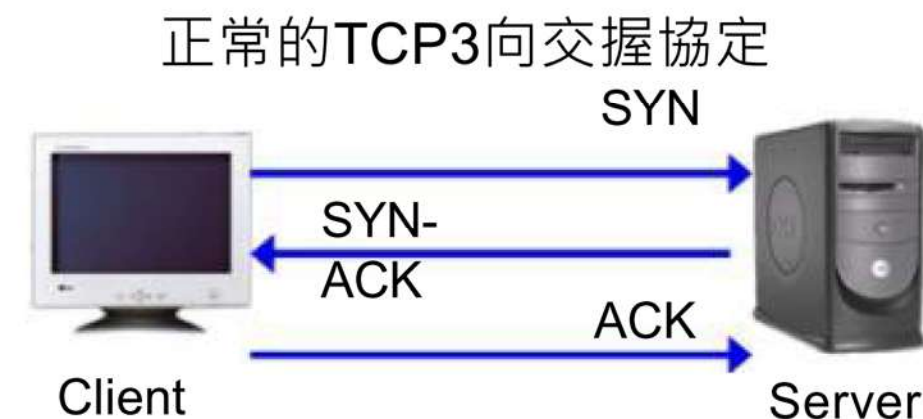
傳輸層攻擊 - SYN Flood

攻擊手法

- ◆ 攻擊者傳送大量的 TCP SYN 請求封包到受害伺服器。
- ◆ 受害伺服器為每一個連線請求分配系統記憶體資源，導致系統連線資源被耗用殆盡，正常的連線無法建立。
- ◆ 大量惡意的 TCP SYN 封包，其來源 IP 通常也都是偽冒的，因此無法以封鎖來源 IP 阻擋攻擊。

防護建議

- ◆ 防火牆限制同來源 IP 的連線數量。
- ◆ 請求 ISP 協助。

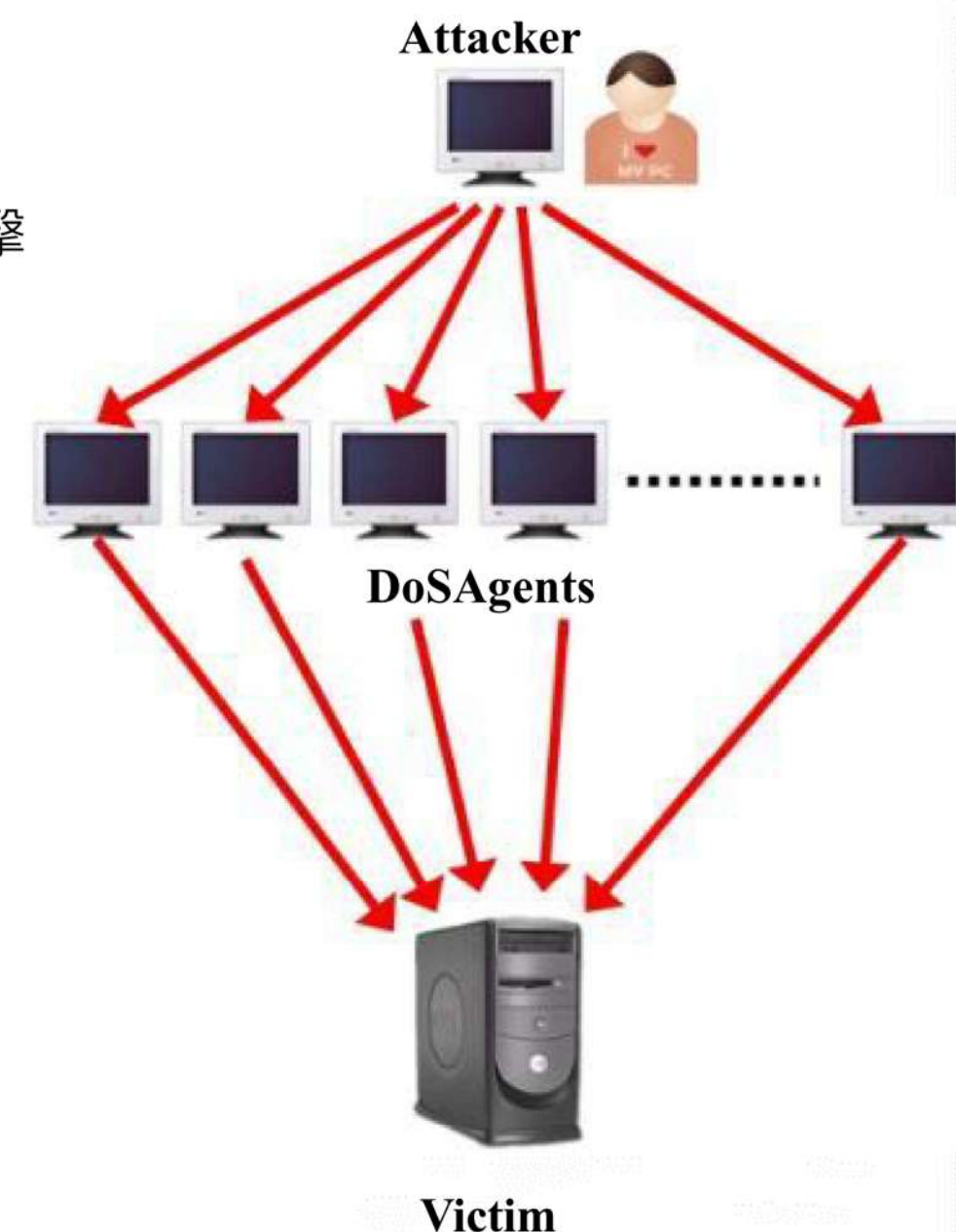


傳輸層攻擊 - DDoS(分散式阻斷服務攻擊)

- ◆ 分散式阻斷服務攻擊(Distributed Denial-of-Service，簡稱 DDoS)。

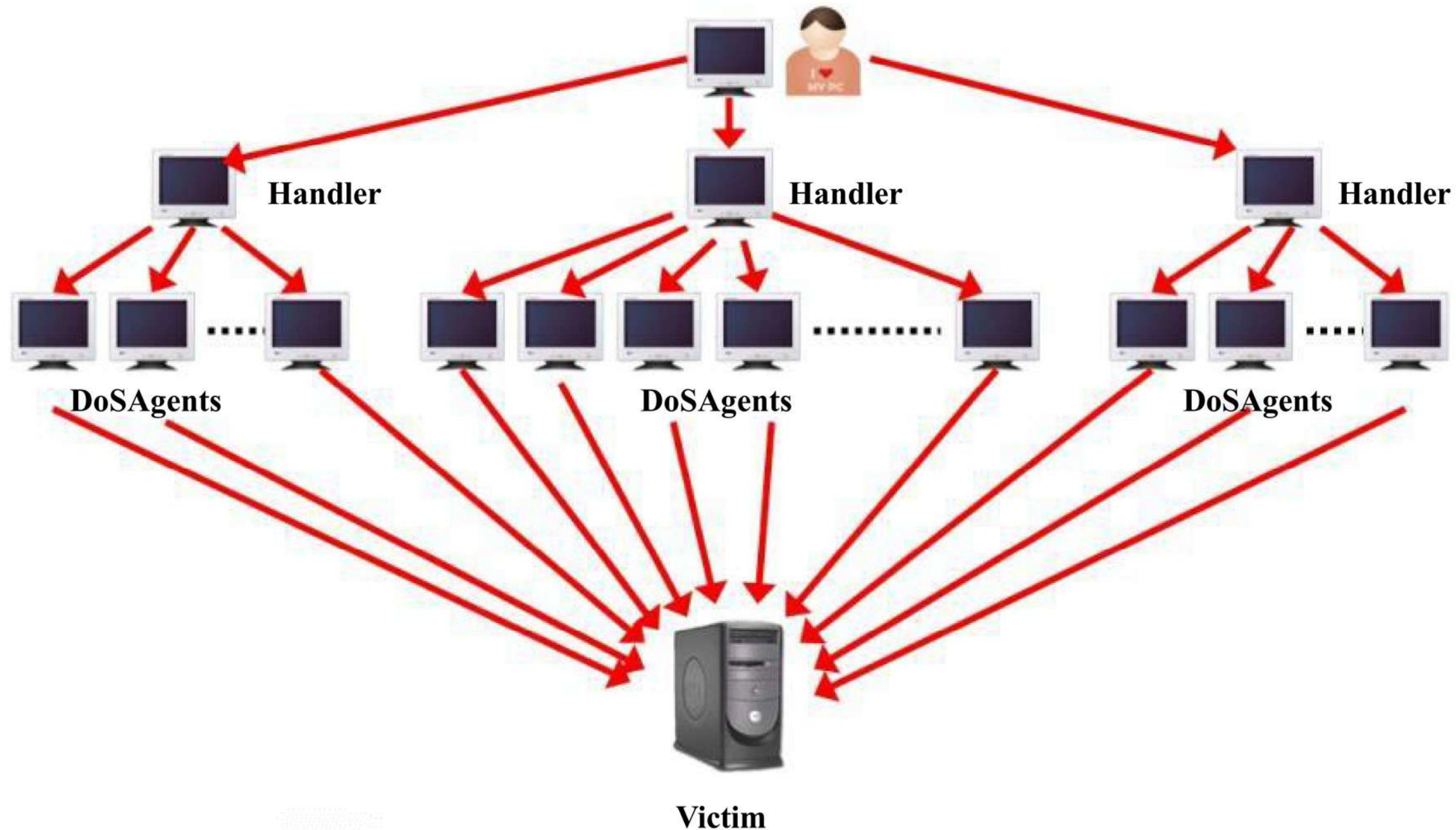
攻擊手法

- ◆ 攻擊者控制多部阻斷服務攻擊主機(DoS Agent)，對受害者發動大規模的阻斷服務攻擊
- ◆ 被攻擊的受害者為主要受害者，被控制的阻斷服務攻擊主機本身也是次要的受害者。
- ◆ 其攻擊來源 IP 太多(數百至數千個)，通常很難透過防火牆封鎖來源 IP。



傳輸層攻擊 - DDoS(分散式阻斷服務攻擊)

◆多層次的控制架構

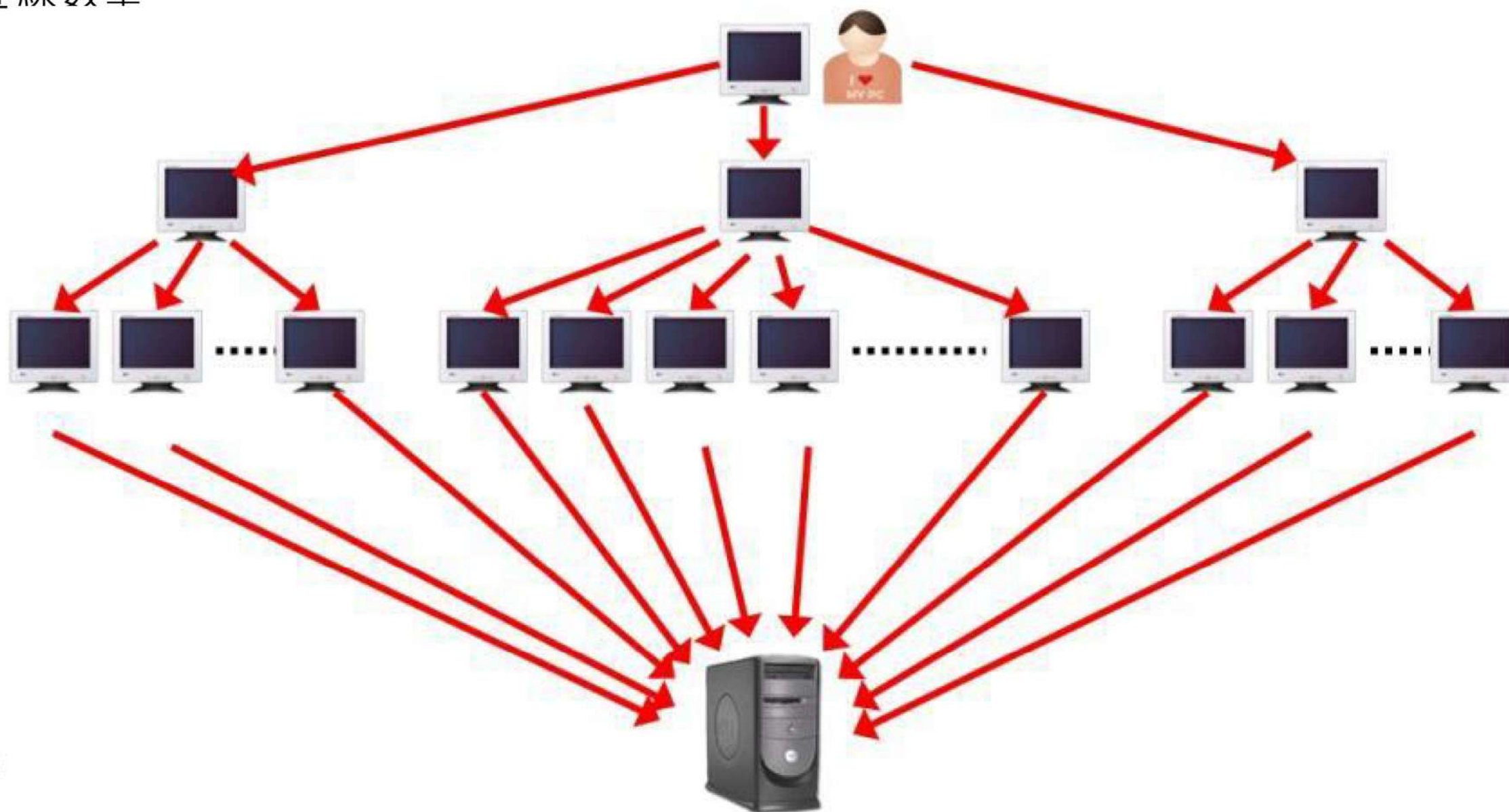


傳輸層攻擊 - DDoS(分散式阻斷服務攻擊)

防護建議

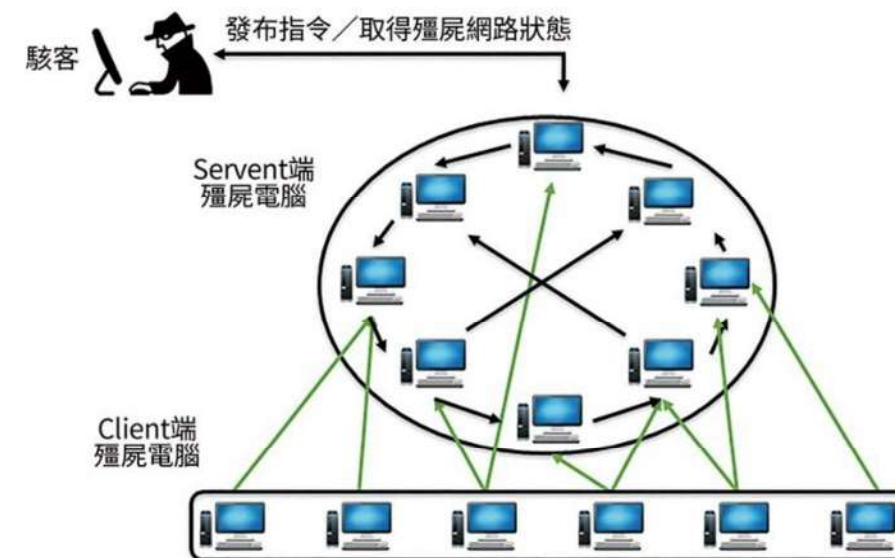
◆ 防火牆限制同一來源IP的連線數量

◆ 請求ISP協助



分散式的癱瘓服務(DDoS, distributed denial-of-service)攻擊

- ◆ 癱瘓服務(DoS, denial of service)攻擊是指駭客利用程式在很短的時間內對攻擊目標的伺服器送出大量的服務請求，造成其主機或網站超過負荷，服務停擺或變緩慢。假如攻擊的程式有多個分散各地，則稱為分散式的癱瘓服務(DDoS)攻擊。
- ◆ 癱瘓服務並不需要破壞被攻擊主機的系統或資料，只要讓服務停擺就有可能造成龐大的損失。
- ◆ 癱瘓服務也可以針對主機的儲存空間進行攻擊，例如造成主機暫存空間爆滿，必須停止運作。
- ◆ 攻擊者可以使用正常的服務與封包，例如 ping 的探詢，可能一般的網站開始不會有警覺。
- ◆ 駭客可使用不正確的封包格式，讓被攻擊的主機處理時耗用資源，最後受到影響。

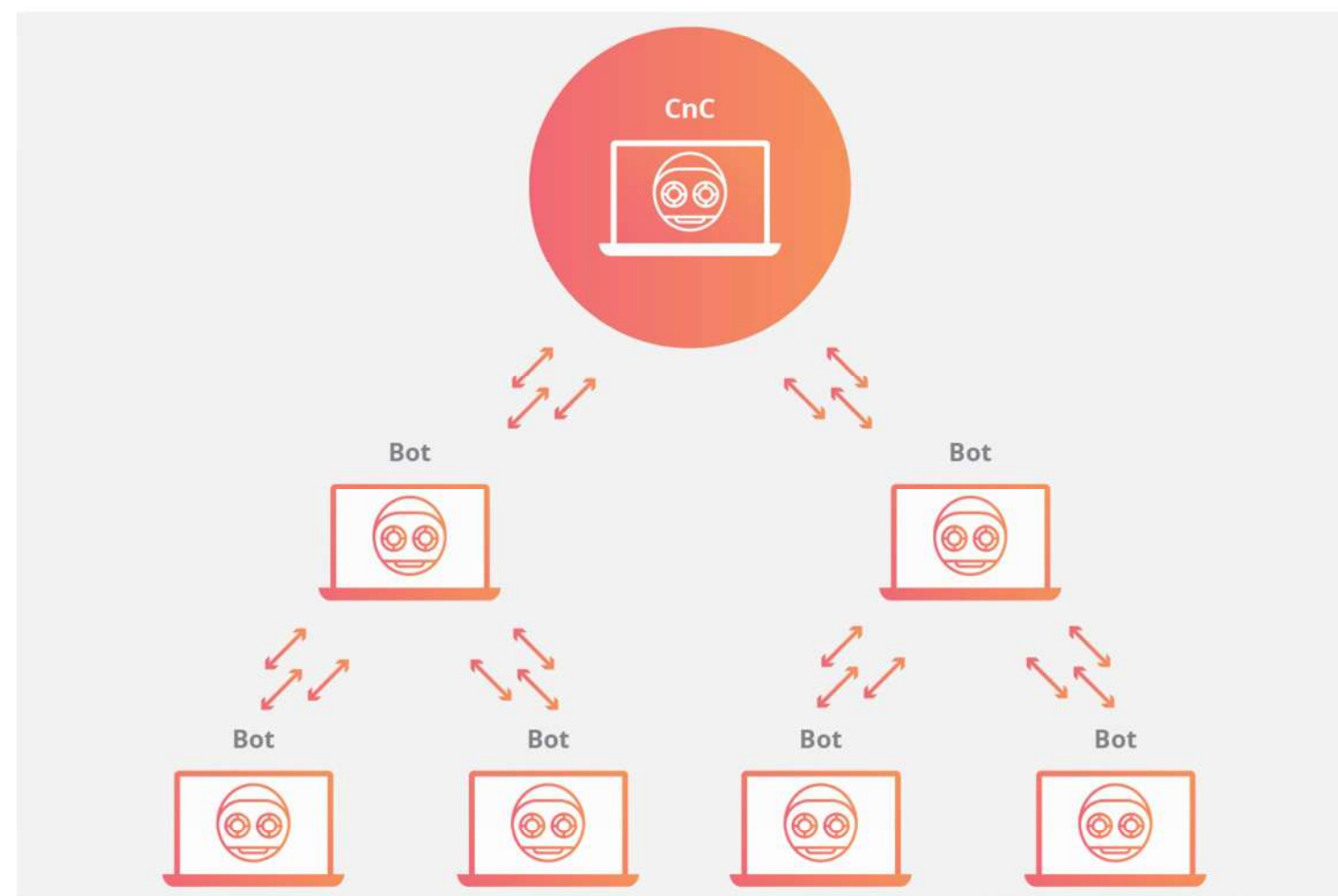
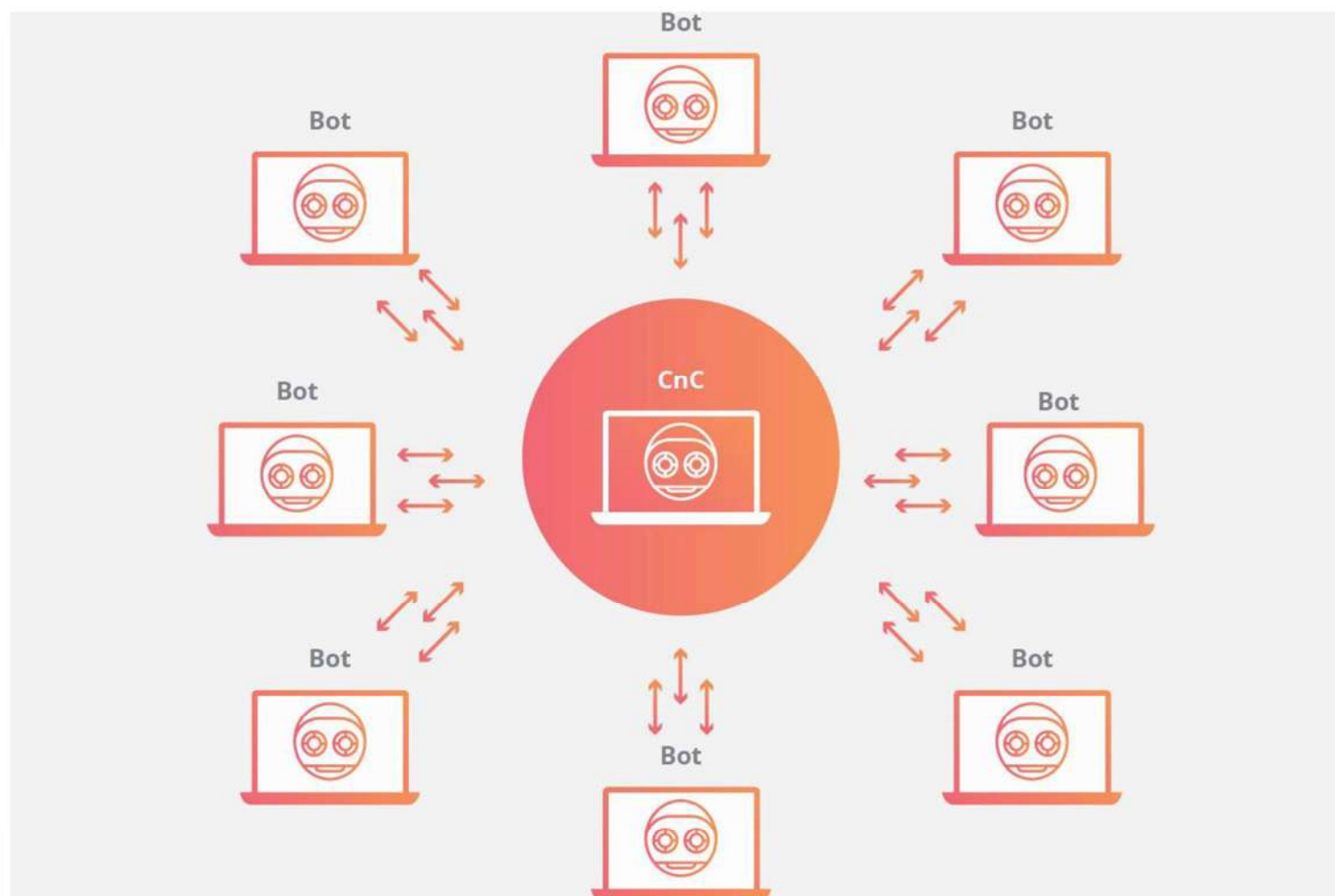


DDoS 與殭屍網路 (botnet)

- ◆ 被殭屍病毒感染的主機會被駭客掌控，這些主機所形成的網路就稱為殭屍網路(botnet)。

殭屍網路可以透過所掌控的主機對其他電腦發送垃圾郵件或是進行 DDoS 的攻擊。

對於受害者來說，不易追查攻擊的真正來源。而且在防禦上比較難針對特定 IP 進行攔阻，使防護的難度增加。



會議層攻擊 - Session Hijacking

◆ 當合法使用者建立連線後，攻擊者從中攔截或取代該連線，可分為兩種類型：

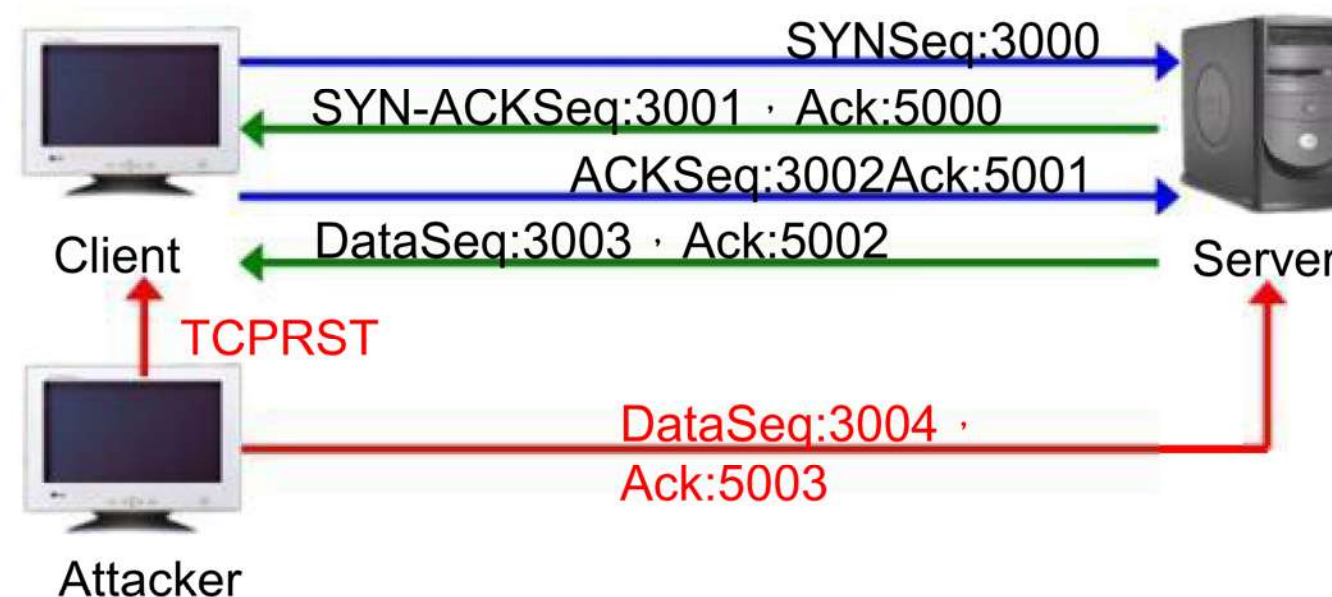
- 主動型：攻擊者取代已建立之有效的連線
- 被動型：攻擊者攔截連線後只監聽連線內容

攻擊手法

- ◆ 追蹤連線過程
- ◆ 連線去同步化
- ◆ 注入攻擊者的封包

防護建議

- ◆ 採用 IPSec 或 SSL 雙向
- ◆ 認證的加密連線



當攻擊者可以預測到 Client 下一個封包的序號時，就可以偽冒 Client 的 IP 送出封包給 Server，達到攔截連線的攻擊

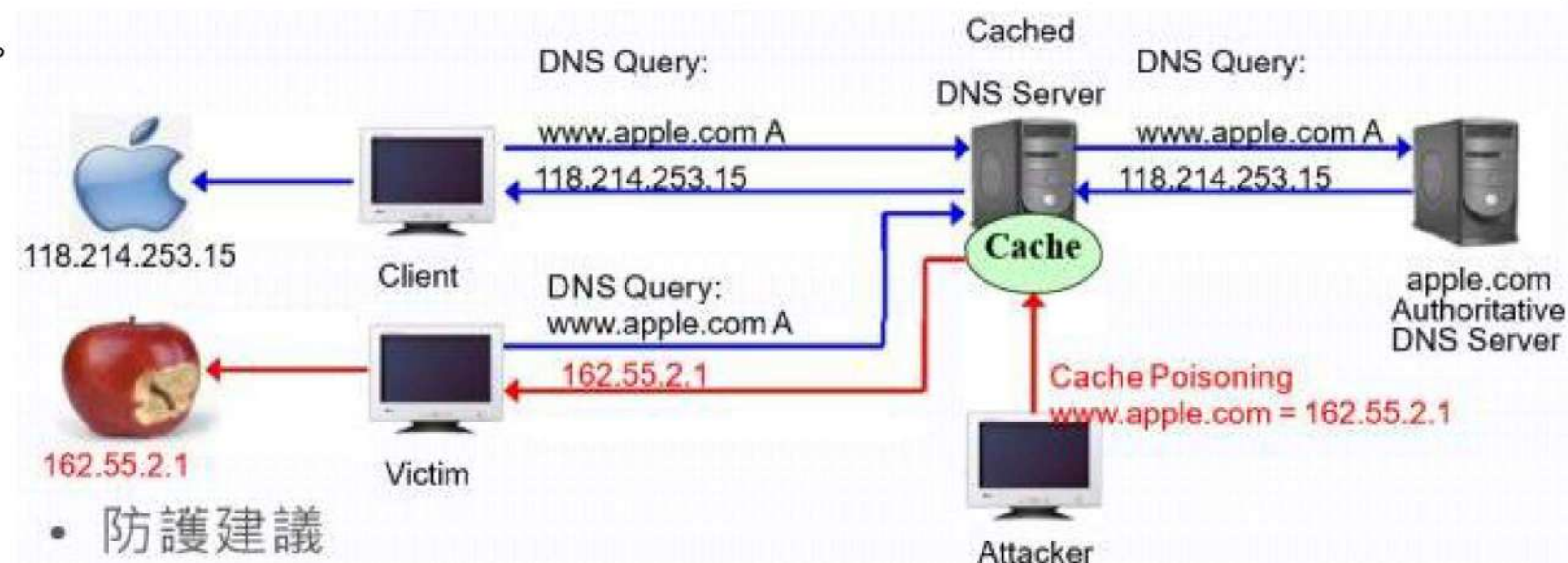
應用層攻擊 - DNS Poisoning

攻擊手法

- ◆ 攻擊者藉由 DNS 伺服器的弱點，將錯誤的名稱解析植入 DNS 伺服器的快取區(Cache)中，導致DNS用戶端解析到錯誤的 IP，使網路連線被導到惡意的伺服器。

防護建議

- ◆ 修補已知的 DNS 伺服器弱點。
- ◆ 區隔外部與內部 DNS 伺服器(不要forward到ISP的DNS)。



應用層攻擊 - Brute force Login

攻擊手法

◆ 攻擊者透過通行碼猜測入侵應用系統的狀況相當常見，例如

➤ TELNETlogin、SSHlogin、FTPlogin

➤ SMTPAUTH、POP3login

◆ 網路上有相當多的工具可自動進行通行碼猜測攻擊

➤ Brutus

➤ THC-Hydra



應用層攻擊 - Brute force Login

防護建議

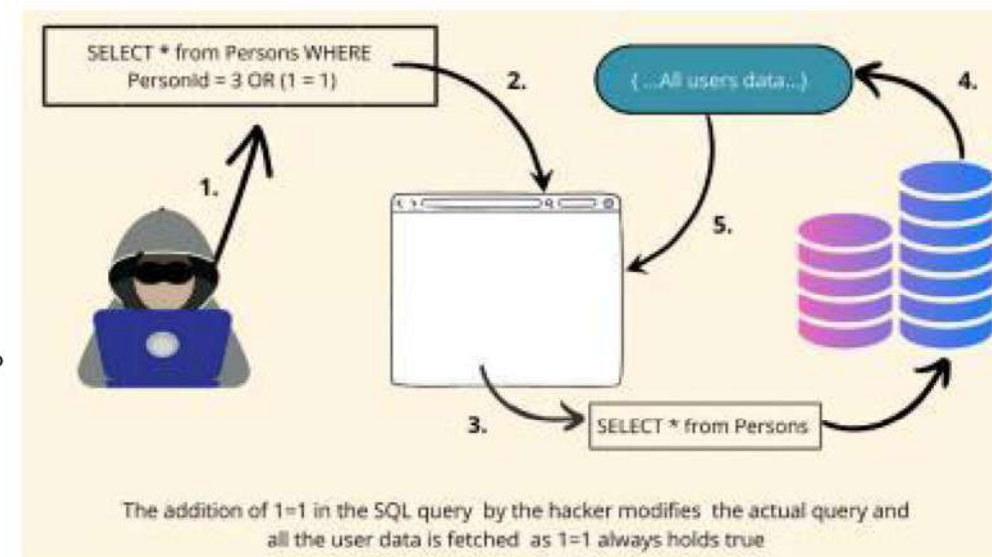
- ◆ 限制同一帳戶連續簽入失敗之次數，若超過次數則延遲簽入一段時間或關閉帳號，發出警告訊息。
- ◆ 強制使用者通行碼長度與複雜度。
- ◆ 定期更換通行碼。



應用層攻擊 - SQL Injection

攻擊手法

- ◆ 弱點原理：Web 應用程式將「不可信任來源」的資訊直接組合成 SQL 語法後執行，就會產生 SQL 語法注入弱點。
- ◆ 攻擊者可以將惡意之 SQL 語法插入程式碼的 SQL 語法中。
- ◆ **BlindSQLInjection**：SQL 語法注入後只回傳某些狀態，無法得知資料內容。
- ◆ SQL 語法注入的弱點發生在Web應用程式中，但受到損害的卻是其後端的資料庫。



可能的損壞

- ◆ 資料庫之資料外洩、資料庫內容被修改、執行資料庫管理、網站權限跳脫或植入後門程式

防護建議

- ◆ 網站應用程式源碼檢測與資料輸出至資料庫前過濾 SQL 語法使用之特殊符號(例如：單引號與分號等)或採參數化查詢語法。

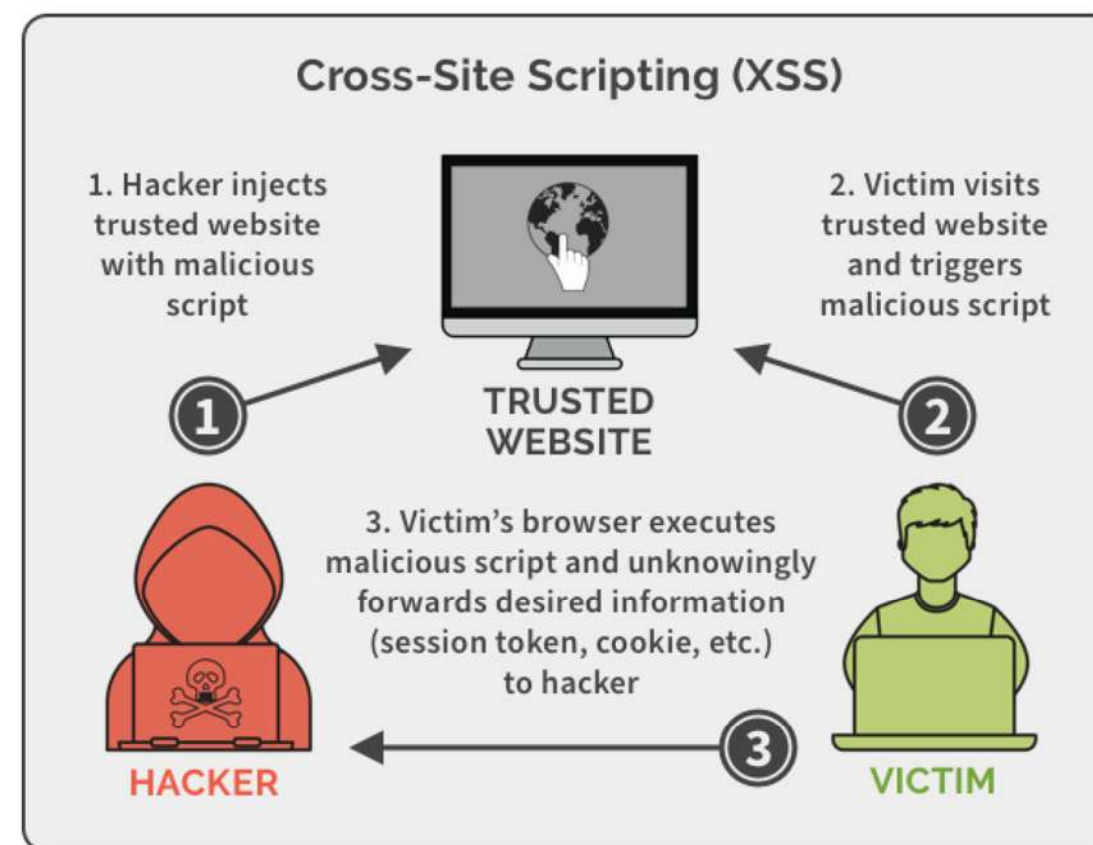
應用層攻擊 - Cross-Site-Scripting

攻擊手法

- ◆ 簡稱 XSS，只用於客戶端的攻擊方式，是攻擊者向有 XSS 漏洞的網站中輸入(傳入)惡意的 HTML 語法(例如 JavaScript)。
當其它用戶瀏覽該網站時，這段 HTML 代碼會自動執行。
- ◆ 當其他使用者瀏覽到被置入惡意腳本的網頁時，使其瀏覽器執行惡意腳本(HTML代碼會自動執行)。

可能的損壞

- ◆ 機密資訊被竊取(例如：Cookie 與 SessionID 等)
- ◆ 下載後門程式植入偽冒資訊
- ◆ 重新導向到其它網站等



應用層攻擊 - Cross-Site-Scripting

•輸入字元檢查：

- 檢查該輸入字串是否含有可疑的script語法
- 這邊要特別強調的是，XSS的防護**不可以只靠輸入的檢查**。
- 要有效防止 XSS 一定要在**輸出檢查並且做適當的Encoding**。

•輸出檢查與Encoding：

編碼後輸出，避免browse執行不必要程式碼，也就是將特殊的字元，特別是<or>轉換為<or>

- &→&(ampersand，U+0026)
- <→<(less-thansign，U+003C)
- >→>(greater-thansign，U+003E)

•安裝防火牆：

- 透過防火牆，在httpcommunicationprotocol過濾相關的XSS

•定期測試與驗證

- 可透過簡單下列語法，於網址、各個可以輸入的欄位與變數輸入下列值，
- 若該網站有XSS弱點，就會出現Test的視窗
- <script>alert('test')</script>

防護方式

對網路各層次的防護建議

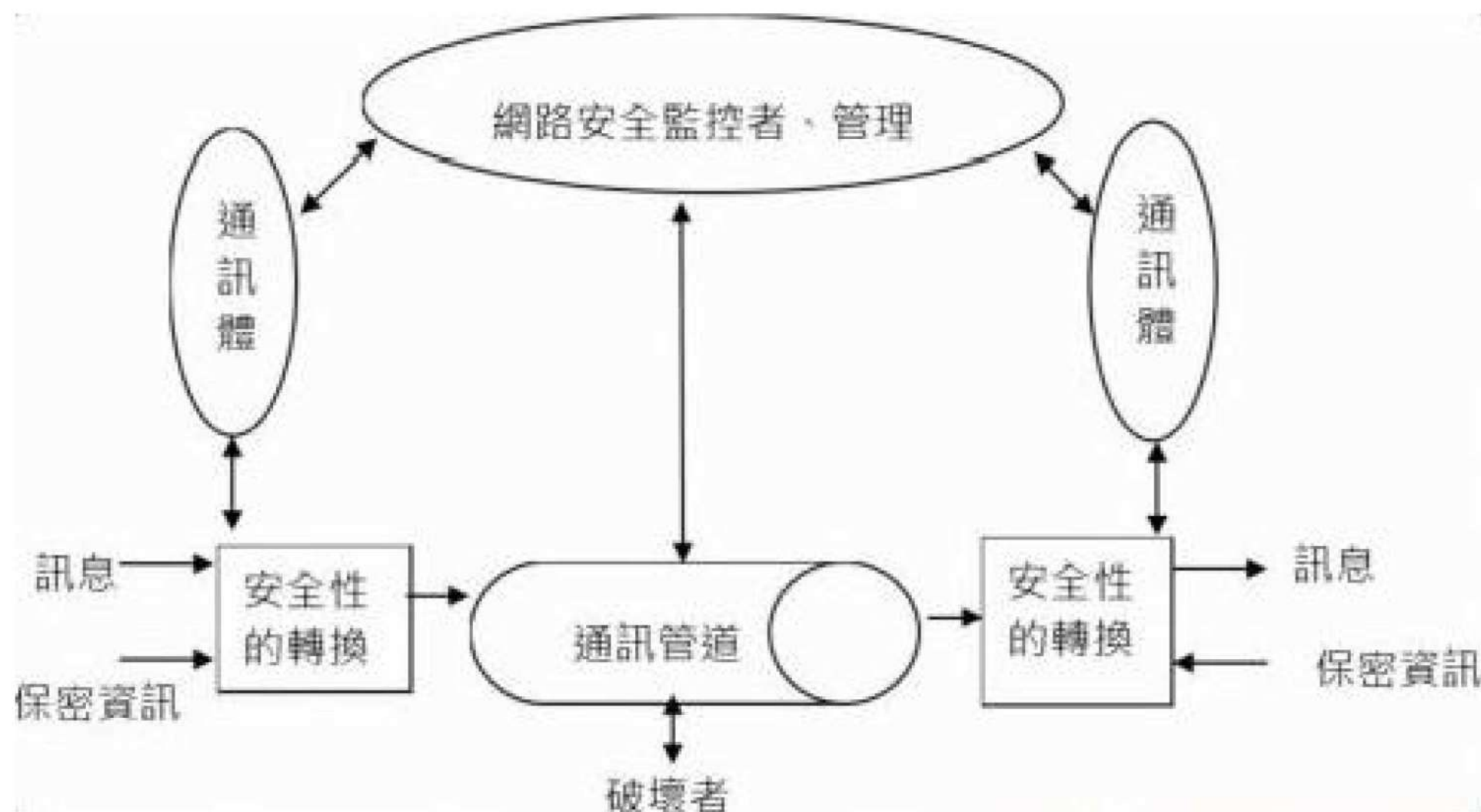
- ◆ **實體層**：機房機櫃與管道間應進行控管，以不同顏色區分不同網段，定期進行線路盤點。
- ◆ **網路層**：在防火牆或路由器阻擋使用 **source route** 的封包，修補作業系統弱點等。
- ◆ **資料鏈結層**：可採用加密連線，以 **VLAN** 縮小廣播範圍，或啟用 **port**、**MAC** 與 **IP** 的對應控管。
- ◆ **傳輸層**：限制同來源 **IP** 連線數，請求 **ISP** 協助處理 **SYN flood**，通訊加密等。
- ◆ **應用層**：應用層的網路攻擊防護可採用修補 **DNS** 伺服器弱點、區分內部與外部 **DNS** 伺服器、強化密碼安全性、網站應用源碼檢測 **SQL** 指令與 **HTML** 特殊符號篩選。

安全模型

- ◆ 可用兩個模型來描述安全服務，一個用來防止破壞者進入網路的途徑，稱為**網路使用安全模型(Network Access Security Model)**，在進入網路資源的通道做好安全檢查。另一個模型是網路資料傳輸時的各種安全機制，稱為**網路安全模型(Network Security Model)**
- ◆ 通訊體是指做網路通訊的使用者(users)或是程式(program)。
- ◆ 通訊體利用保密資訊，將訊息轉換成難以辨讀的型式，才進行傳送。
- ◆ 接收訊息的通訊體須從網路安全的監控者那兒，得到相對應的保密資訊，方能解讀所收到的訊息。
- ◆ 對訊息所做安全性轉換，有各種方式，目的是使破壞者即使得到轉換後的訊息，也無法使用。

網路安全模型

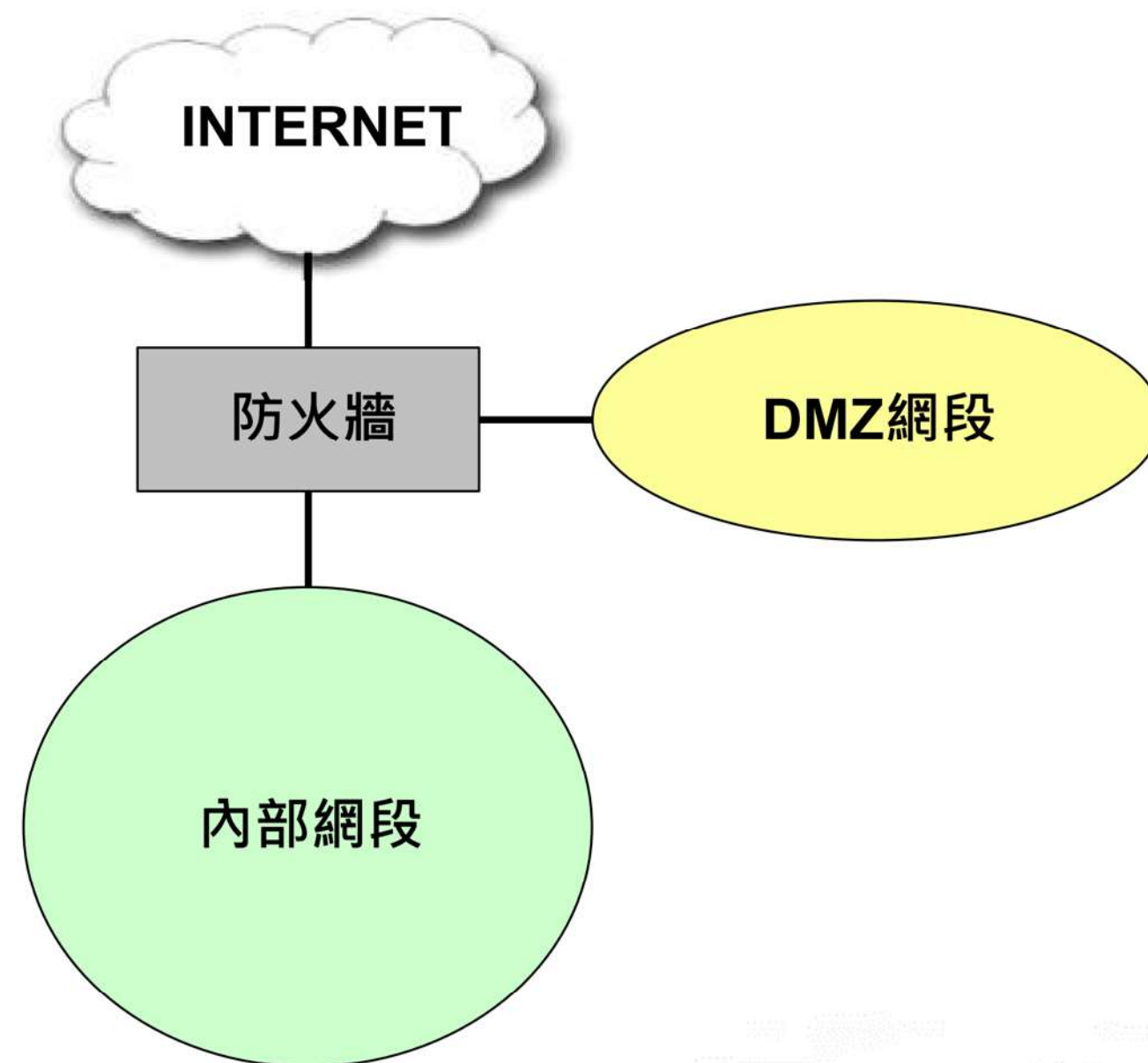
- ◆ 系統的保護(protection)嚴格說來是一種內部的問題，安全(security)問題必須進一步地考慮到系統所處的外在環境。
- ◆ 當然，有些安全問題是管理問題，與作業系統的安全機制無關。基本上，不管是電腦裡的資訊，或是實體的資源，都應該受到保護。



防火牆

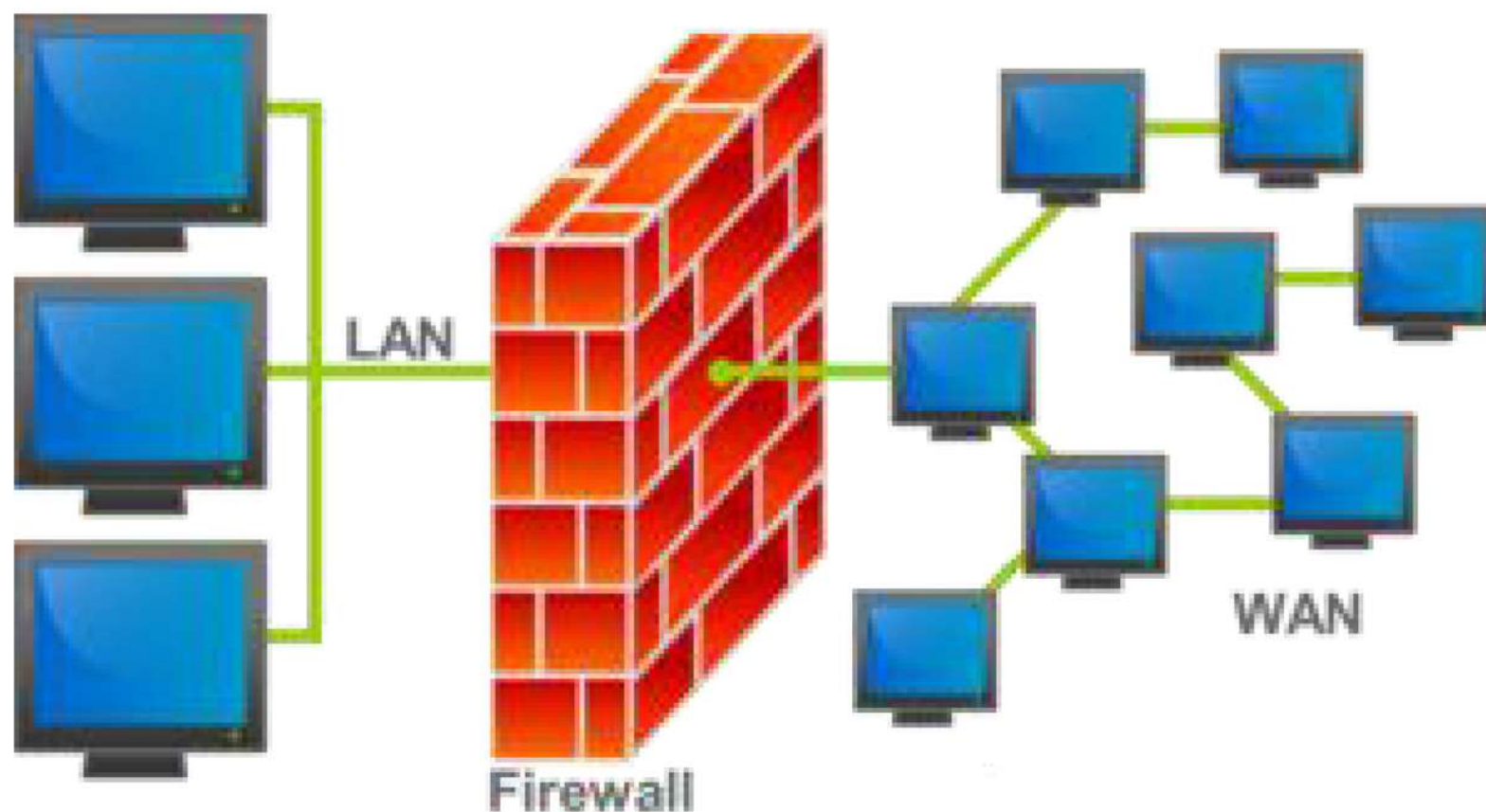
主要用途

- ◆ 區隔不同安全等級網段(例如：外部網路、內部網路及DMZ)。
- ◆ 偵測與阻擋網路層與連線層的攻擊。
- ◆ 落實網路存取政策。



防火牆(firewall)

- ◆ 區隔不同安全等級的網段，偵測並阻擋網路的攻擊。公開伺服器應位於 DMZ 網段，重要的伺服器位於內網，內對外的連線也應控管，存取規則的變更要依據管理程序。
- ◆ 封包過濾型的防火牆只判定封包的 port 與 IP，連線過濾型的可掌握 TCP/UDP 連線狀態，應用代理型的可確保連線協定正常使用，連線狀態檢查型支援動態封包過濾技術。



防火牆(firewall)

管理重點

- ◆ 防火牆存取規則的變更應建立管理程序(變更申請、核准及記錄)。
- ◆ 防火牆存取紀錄應即時匯出存檔，並保留足夠的時間。
- ◆ 定期產出異常存取統計分析報表，進行異常處理。
- ◆ 防火牆存取控管規則應定期盤查(每年)。

選購時重要規格

- ◆ 防火牆本身的安全性(可參考Common Criteria EAL認證)、可區隔的網路區段數應符合組織需求(外、內及 DMZ)、可支援的傳輸頻寬大小符合組織需求。
- ◆ 應可支援阻斷服務攻擊的偵測與防護。

入侵偵測與防禦系統

主要用途

- ◆ 識別網路的異常行為與攻擊行為(注意：SSL 加密連線的內容無法識別)。
- ◆ 特定無誤判之攻擊行為可以立即阻擋。

入侵偵測與防禦系統類型

◆ 特徵碼比對：

- 比對攻擊特徵碼、判斷較精準。
- 只能偵測已知攻擊。

◆ 異常行為模式分析：

- 統計分析。
- 較易誤判。
- 能偵測未知類型攻擊。

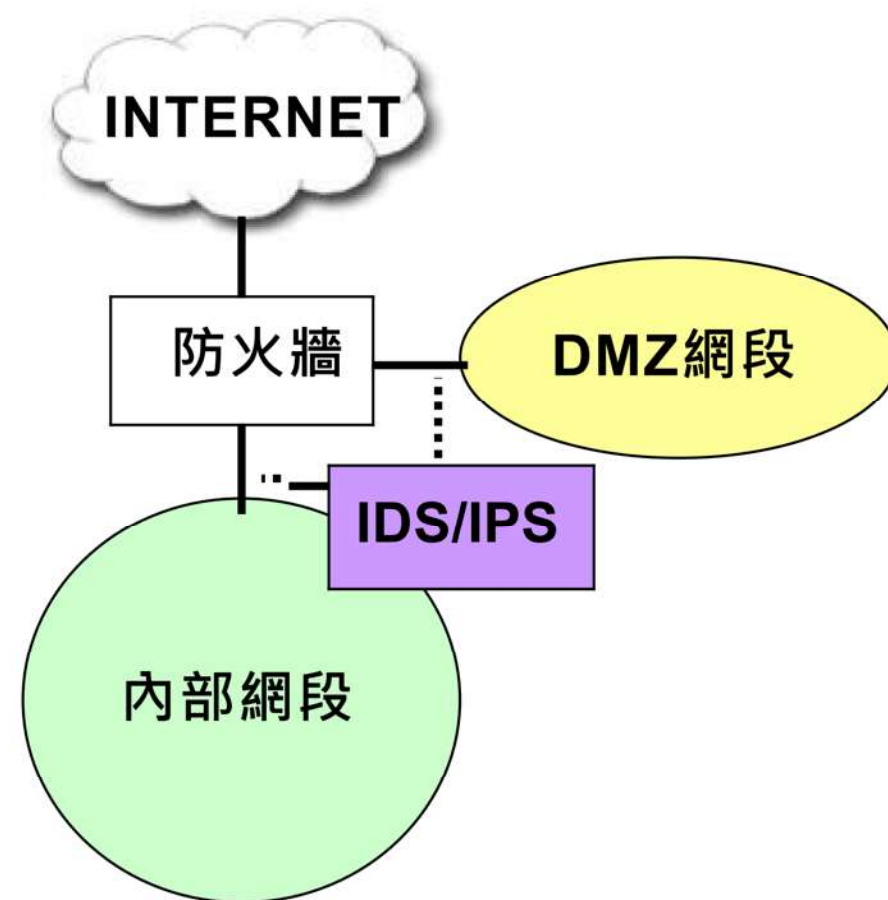
入侵偵測與防禦系統

入侵偵測的反應方式

- ◆ 主動方式：立即將攻擊事件或攻擊來源進行封鎖。
- ◆ 被動方式：只將異常事件記錄下來，供日後稽核分析使用。

入侵偵測的部署

- ◆ 監聽模式：不影響網路部署，但防禦效果較差。
- ◆ Bridge 模式：防禦能力較強可以阻擋 TCP/UDP 的攻擊。
- ◆ 主要偵測 DMZ 與內部網段進出口。



入侵偵測與防禦系統

管理重點

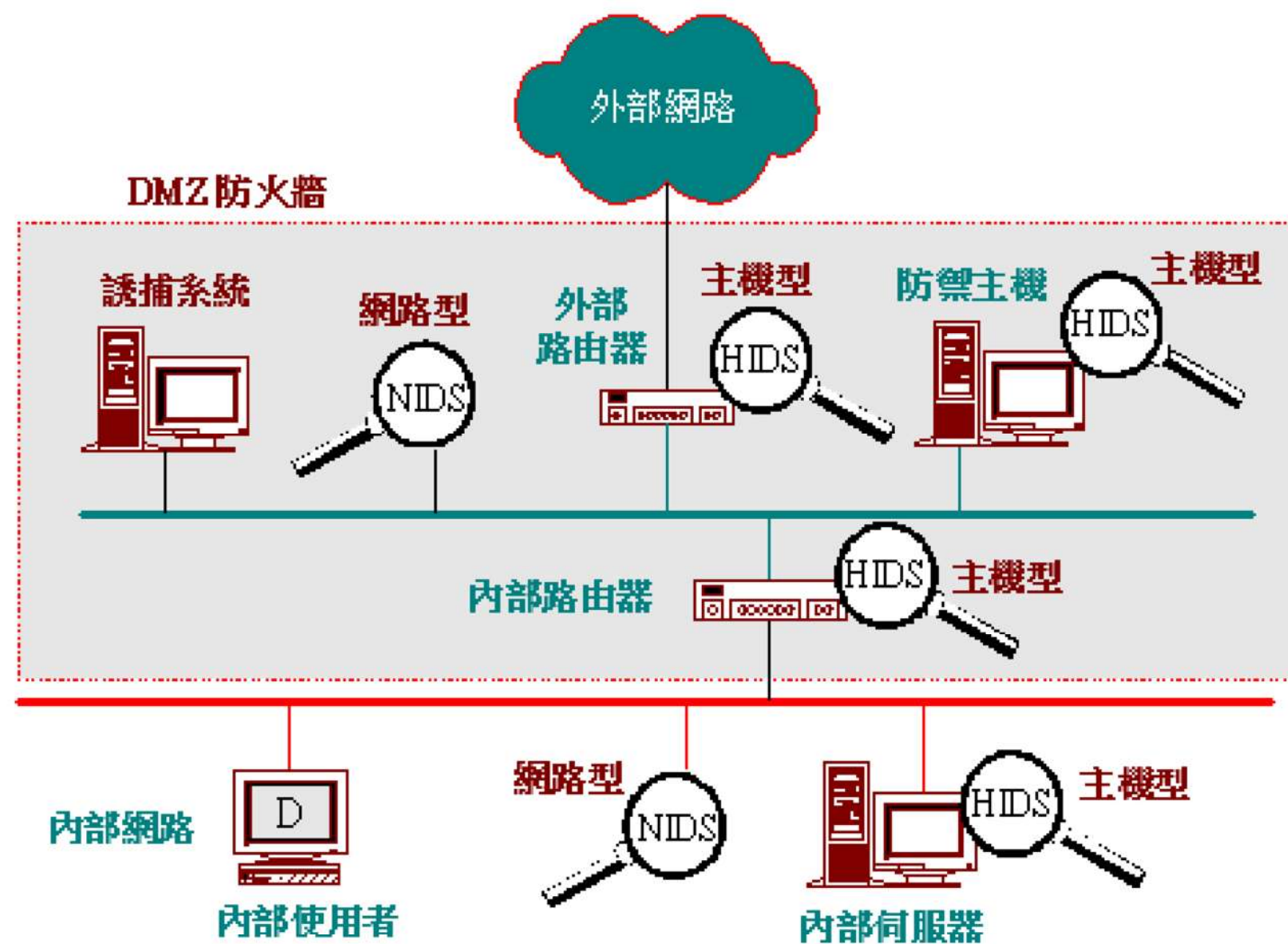
- ◆ 入侵行為特徵碼應隨時更新。
- ◆ 入侵偵測之異常事件應定期分析(每週)，或委由資安監控中心隨時監控。
- ◆ 入侵偵測存取紀錄應即時匯出存檔，並保留足夠的時間。

選購時重要規格

- ◆ 可偵測的網路區段數應符合組織需求(內與DMZ)。
- ◆ 可支援的頻寬大小符合組織現有網路狀況。

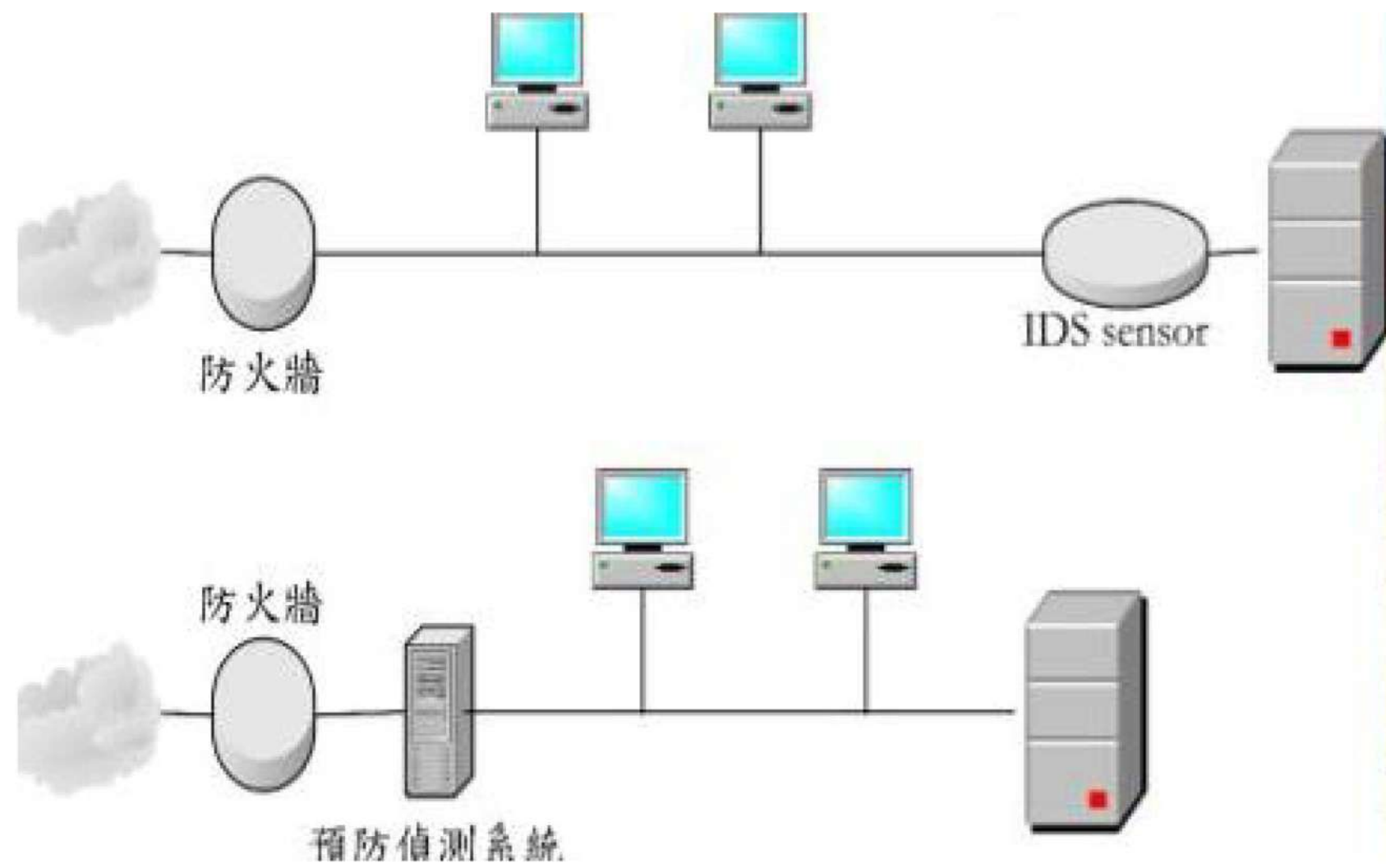
入侵偵測(intrusion detection)

- ◆ 入侵偵測系統(IDS, intrusion detection system)跟防火牆的功能是不同的，入侵偵測的目標在於發現違反安全要求的行為。
- ◆ 只要有可疑的活動，嘗試進入管制中的電腦系統或是網路，IDS 就必須試著偵測到，並且發出警訊，迅速回報。



入侵預防系統(intrusion prevention systems)

- ◆ 企業在採用各種 IDS 產品之後可能還是不滿意這種防治的方法，希望能有更積極創新的做法。
- ◆ 所謂的入侵預防系統(IPS, intrusion prevention systems) 會偵測可疑的活動，而且進一步地防止活動延伸成不法進入系統的結果。IDS 與 IPS 之差異，不在於是否擺放在防火牆的後端，而在於是否有阻擋攻擊封包的能力。



虛擬私有網路系統

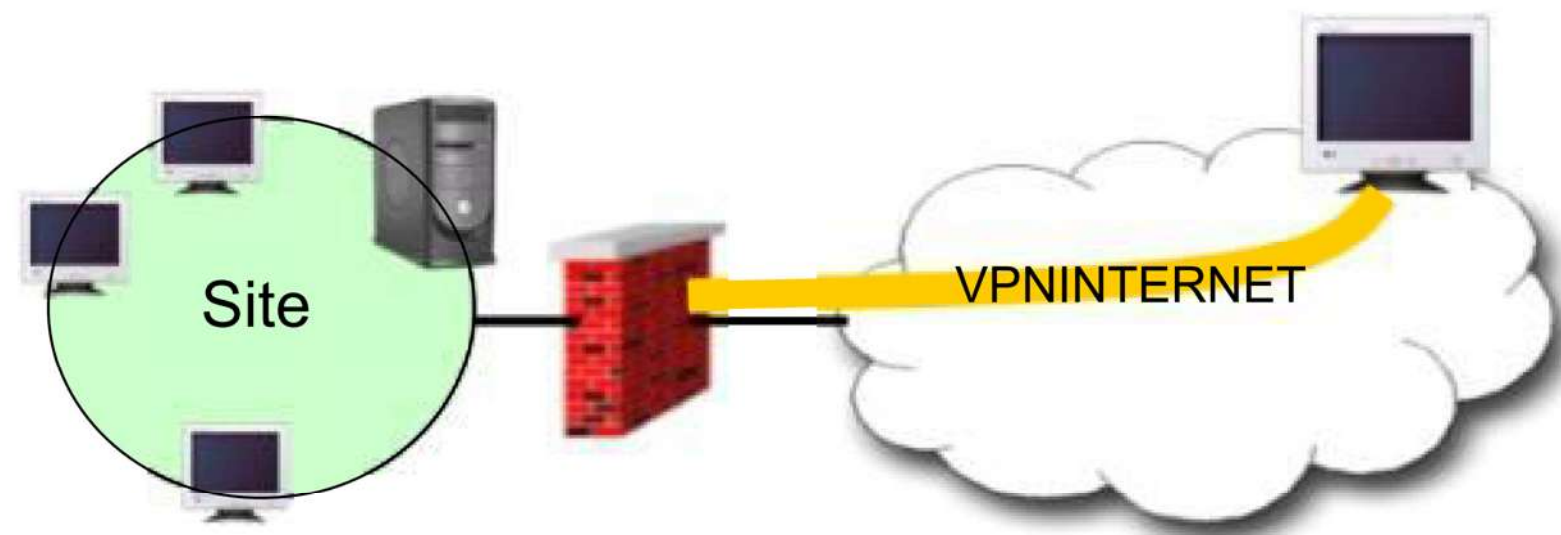
- ◆ 虛擬私有網路(Virtual Private Network，簡稱VPN)。

主要用途

- ◆ 在公開的網路上建立私有的安全通道。
- ◆ 包含身分鑑別與加密以保護通訊資料的完整性與機密性。

VPN的類型

- ◆ 遠端使用者存取 VPN：外勤人員透過網際網路與內部網路建立的安全通道。

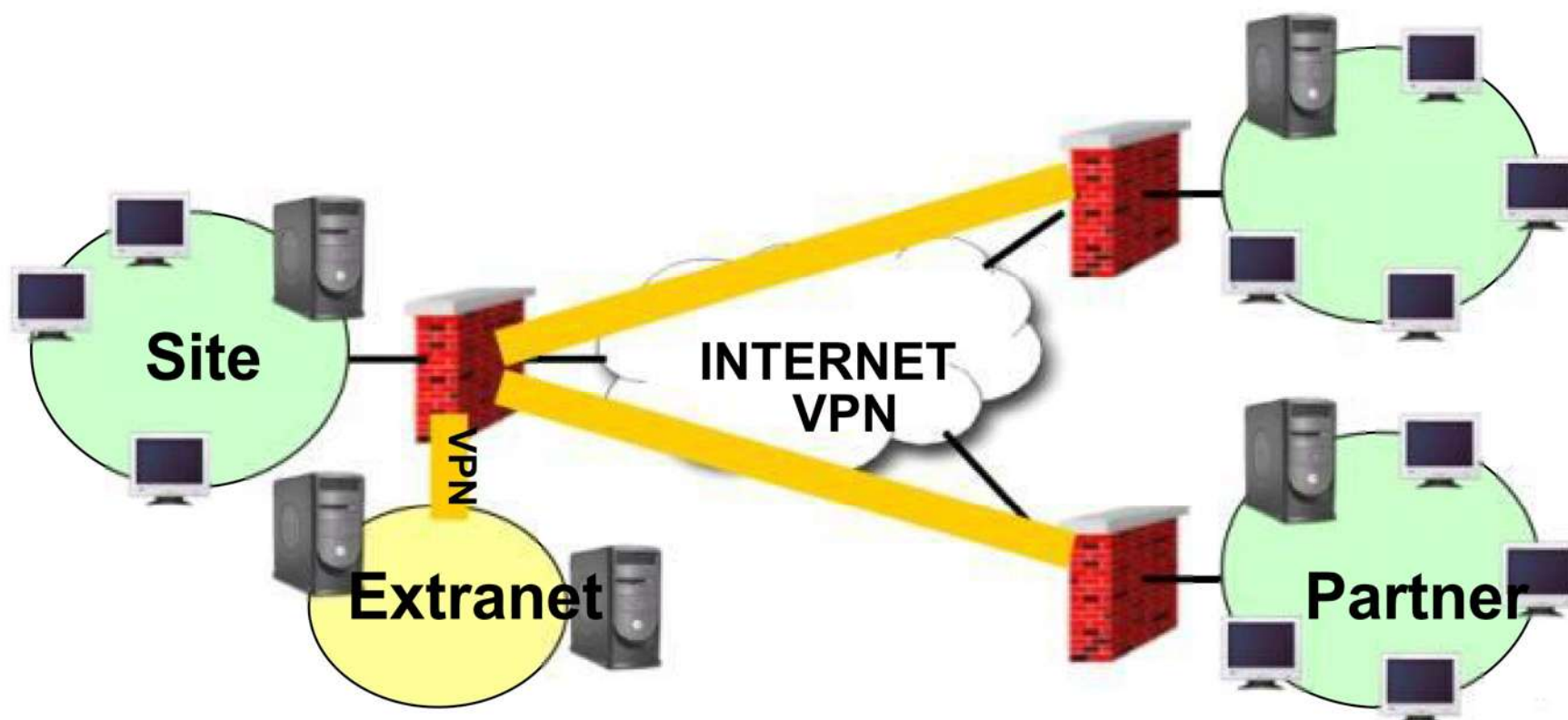


虛擬私有網路系統

◆ **Site-to-Site VPN**：總部與分點之內部網路透過網際網路建立安全通道



◆ **Extranet VPN**：與合作伙伴間透過網際網路建立安全通道(注意存取權限的控管)



虛擬私有網路系統

使用VPN的好處(與實體私有網路比較)

- ◆部署較彈性
- ◆可擴充性較高
- ◆線路成本較低

VPN協定

- ◆PPTP : Point to Point Tunnel Protocol(OSIL2)
- ◆L2TP : Layer2 Tunneling Protocol(OSIL2)
- ◆IPSec : 適用於遠端使用者存取 VPN、Site-to-Site VPN 及 Extranet VPN
- ◆SSL : 好處是不必裝任何用戶端軟體，瀏覽器幾乎都有支援
- ◆目前大部份防火牆產品已內建 VPN 功能

虛擬私有網路系統

管理重點

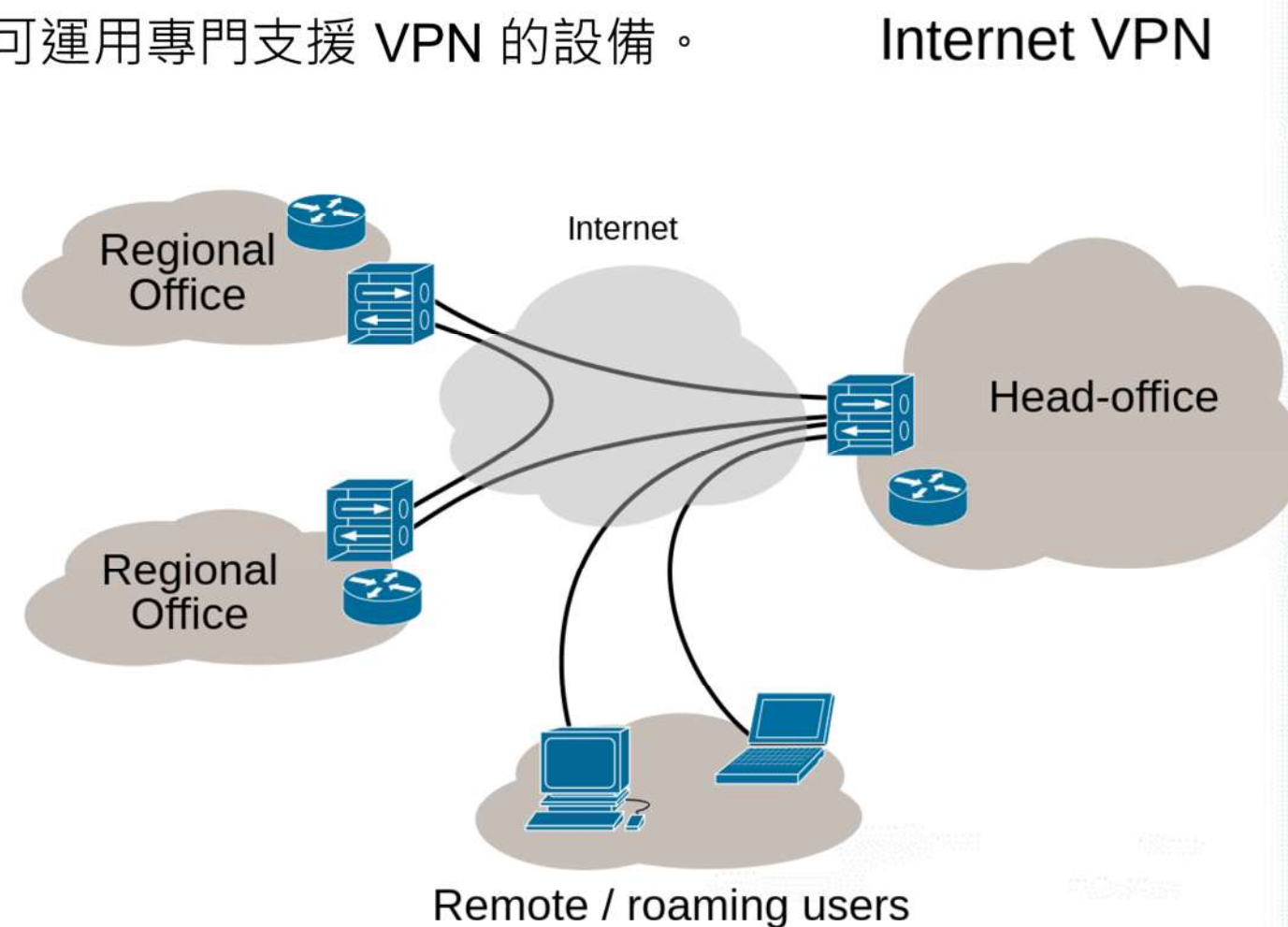
- ◆ 虛擬私有網路的建立與使用者帳號的申請，應建立管理程序(變更申請、核准及記錄)
- ◆ 定期分析異常事件，例如：VPN 使用者簽入失敗
- ◆ VPN 存取紀錄應即時匯出存檔，並保留足夠的時間

選購時重要規格

- ◆ 可支援的 VPN 數量或使用者連線數量應滿足組織需求
- ◆ 本身應具備防火牆功能，以控管 VPN 連線的存取
- ◆ 與其他不同廠牌產品建立 VPN 連線的相容性

虛擬私有網路(VPN)

- ◆ 利用公開的網路進行通訊，但是必須建立安全的通道，這樣的技術稱為虛擬私有網路(VPN，virtual private network)，通常需要進行身份鑑別與資料的加密。
- ◆ VPN 在應用上可讓遠端使用者透過 VPN 對系統進行存取，或讓人員透過網際網路與內部網路建立安全通道。
- ◆ 機構在不同地區的單位之間也可以透過 VPN 建立安全的通訊管道，可運用專門支援 VPN 的設備。
- ◆ 實體的私有網路也可以支援安全的通訊管道，
但是 VPN 部署比較有彈性、成本較低，而且較容易擴充。
- ◆ 很多防火牆設備內建了 VPN 的功能，常見的相關協定包括 PPTP、L2TP、SSL 與 IPSec 等。



防毒系統

- ◆ 防毒系統對於機構或是個人來說，都是相當普遍的防護方式，所防禦的包括一般的電腦病毒程式、木馬、後門程式、蠕蟲與間諜程式等。這些惡意程式經常以網路為媒介入侵。
- ◆ 一般人可能在進行網站瀏覽的時候下載了含有病毒的檔案或是點按了不該執行的程式。
- ◆ 使用網路的時候收到不明來源的檔案，而且開啟或是執行這些檔案。
- ◆ 使用電子郵件系統點按了惡意的連結，或是開啟了不明來源的附檔。
- ◆ 使用社群軟體時點按了惡意的連結，或是儲存不明來源的檔案或是程式。



防毒系統

主要用途

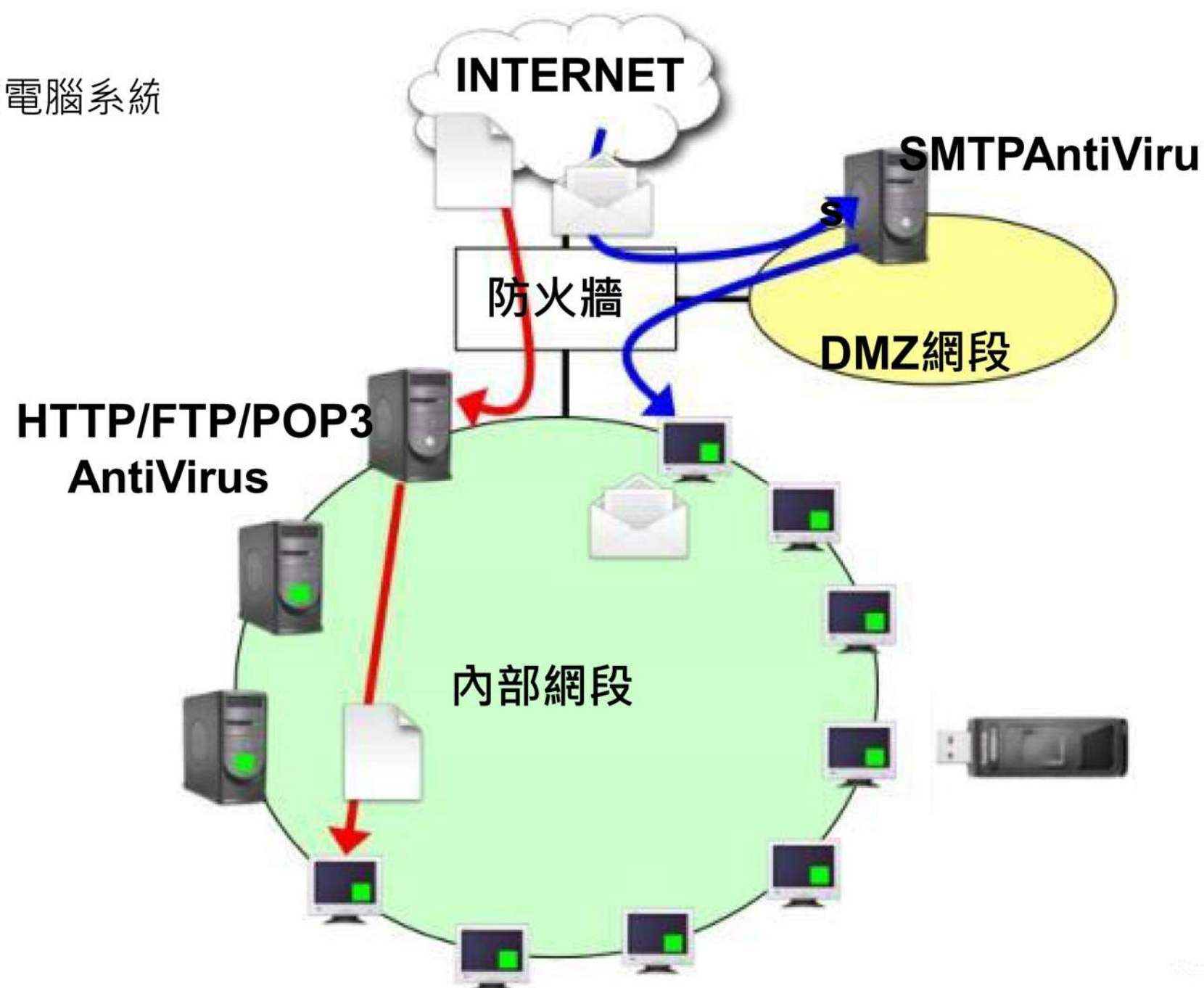
- ◆ 防止病毒、蠕蟲、間諜、後門及木馬等惡意程式入侵電腦系統

惡意程式的來源

- ◆ 電子郵件
- ◆ USB硬碟
- ◆ 網站瀏覽
- ◆ 即時通訊
- ◆ 檔案傳輸/分享

全面防毒的部署

- ◆ 個人電腦與伺服器防毒
- ◆ 電子郵件防毒匣道
- ◆ 上網防毒匣道



防毒系統

管理重點

- ◆ 應定期自動更新病毒碼
- ◆ 病毒感染的事件與趨勢應定期分析
- ◆ 避免未安裝防毒軟體的電腦上線(配合上網管控設備)
- ◆ 防火牆控管未經防毒匣道過濾的連線行為
- ◆ 個人電腦與伺服器防毒系統」與「防毒匣道系統」可採用不同廠牌

選購時之重要規格

- ◆ 病毒偵測的精準度、對電腦效能的影響
- ◆ 是否提供中央控管機制
- ◆ 可支援的網路連線偵測能力(電子郵件與即時通訊)

垃圾郵件過濾系統

主要用途

- ◆ 過濾垃圾與廣告郵件
- ◆ 避免電子郵件社交工程攻擊
- ◆ 提升人員電子郵件使用安全

垃圾郵件的判斷技術

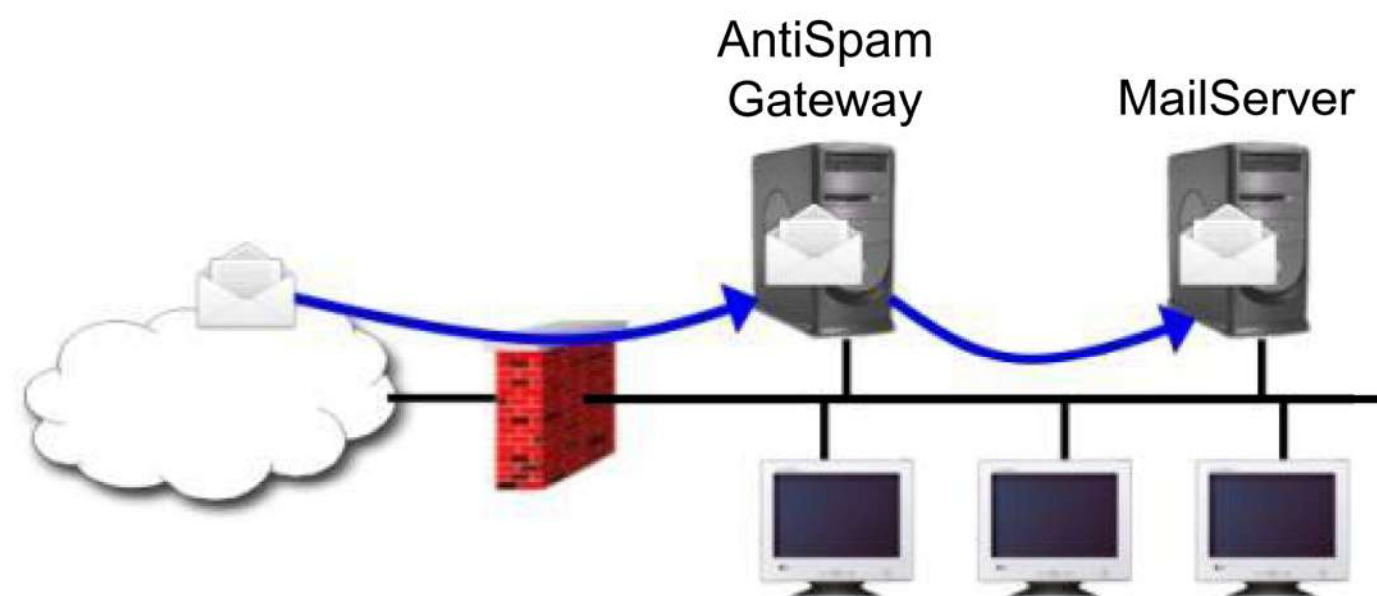
- ◆ 關鍵字比對(中文字，包含附件)
- ◆ 內容過濾條件
- ◆ 外部資料庫比對(DCC、Razor、Pyzor)
- ◆ 貝氏演算法(自動學習機制)
- ◆ 圖片辨識技術

垃圾郵件過濾系統

部署方式

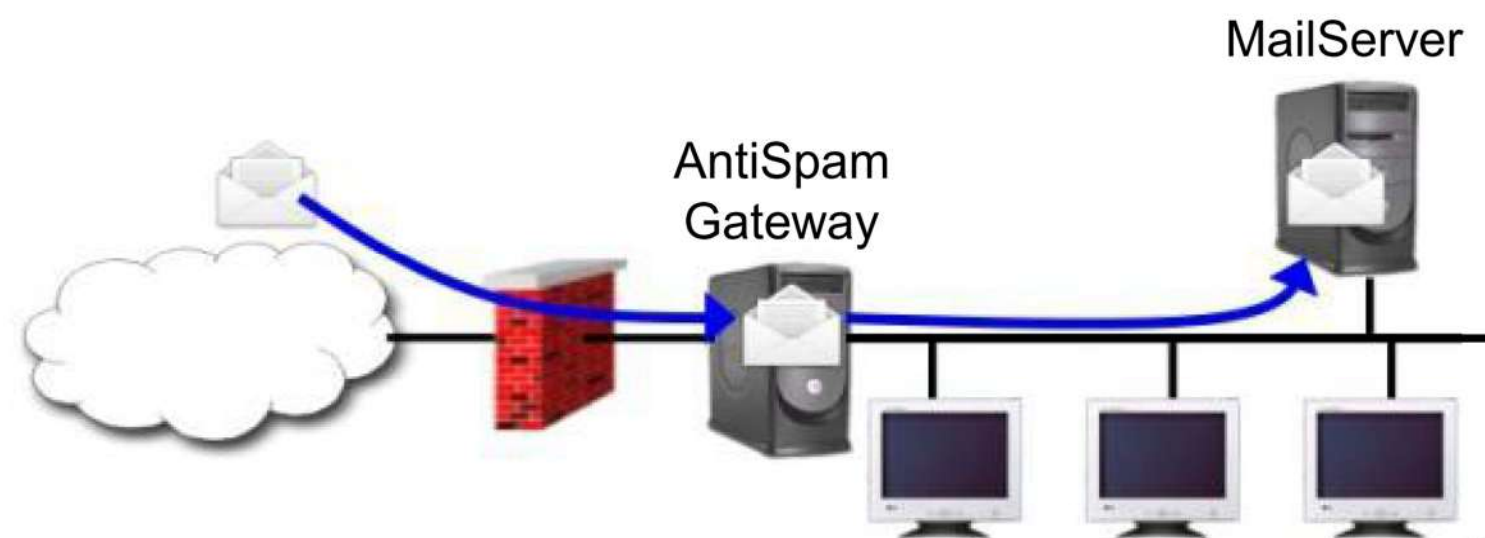
◆ 匣道模式(Mail Relay)

- 不影響其他網路流量
- 設備故障時信件無法進出
- 安全性高(Fail Close)



◆ Bridge 模式(目前較少見)

- 會影響其他網路流量
- 設備故障時會自動 Bypass 流量
- 安全性較低(Fail Open)



垃圾郵件過濾系統

管理重點

- ◆ 應定期自動更新垃圾郵件辨識特徵碼
- ◆ 電子郵件過濾規則的變更應建立管理程序(變更申請、核准及記錄)

選購時之重要規格

- ◆ 垃圾郵件判斷的精準度
- ◆ 處理效能可符合組織需求
- ◆ 對於中文信件或多國語言的支援能力
- ◆ 全文檢索支援中文的能力與郵件附件的檢索能力
- ◆ 圖片廣告信件的支援能力

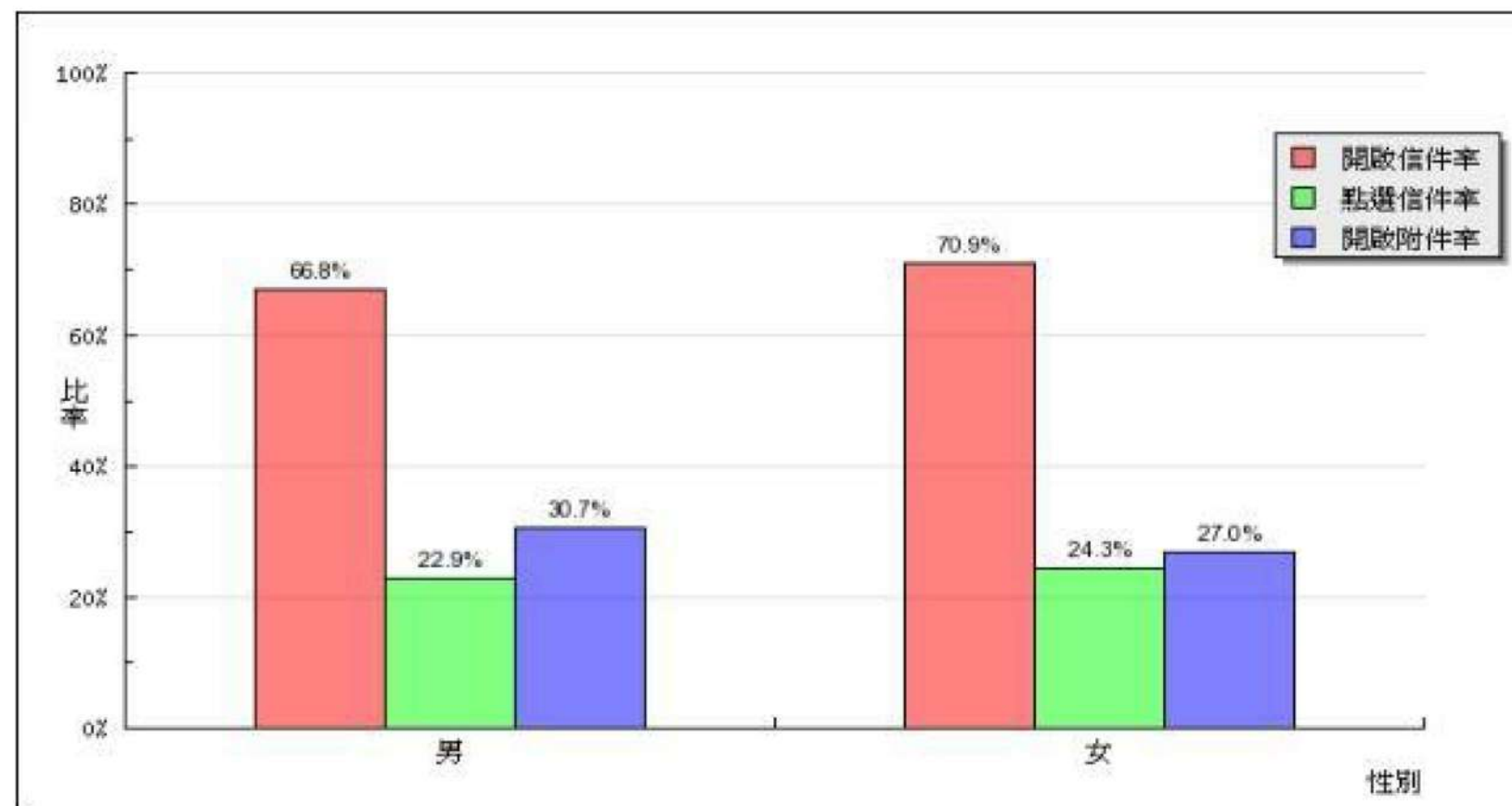
電子郵件社交工程攻擊與防護

技術面防護

- ◆ 建置垃圾郵件過濾系統
- ◆ 用戶端郵件收發軟體(例如：Outlook)的安全設定
 - 以文字模式閱讀信件
 - 關閉自動下載外部元件
 - 關閉「收件匣」預覽視窗

管理面防護

- ◆ 訂定使用者電子郵件使用規範
- ◆ 定期實施電子郵件安全宣導課程
- ◆ 定期實施電子郵件社交工程演練，並針對未符合使用規範的人員進行宣導或訓練



網站應用程式防火牆

主要用途

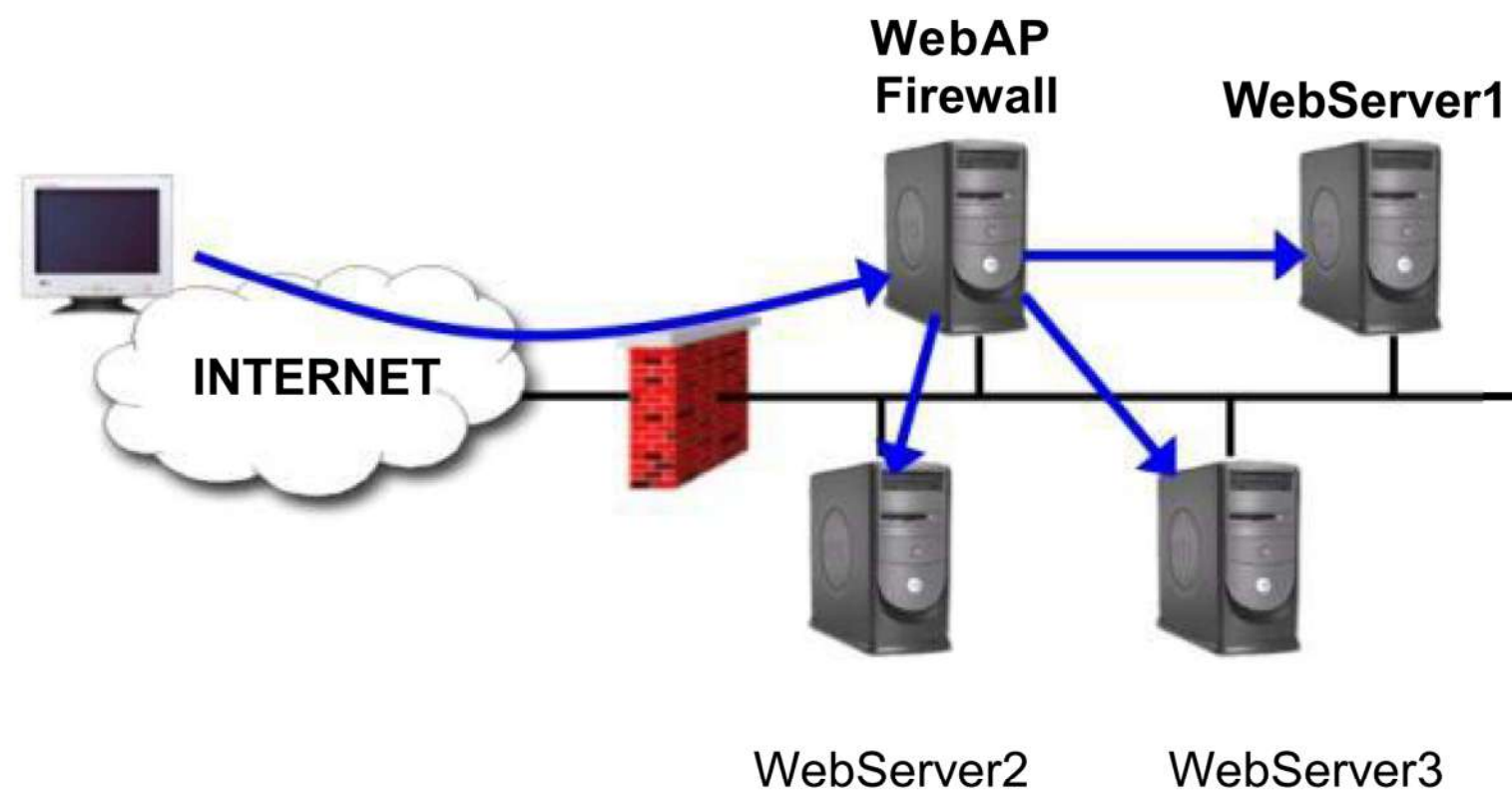
- ◆ Web Application Firewall，簡稱 WAF。
- ◆ 偵測與防禦針對網站應用程式之攻擊行為。
- ◆ 例如：SQL Injection 與 Cross- Site Scripting。

偵測與過濾技術

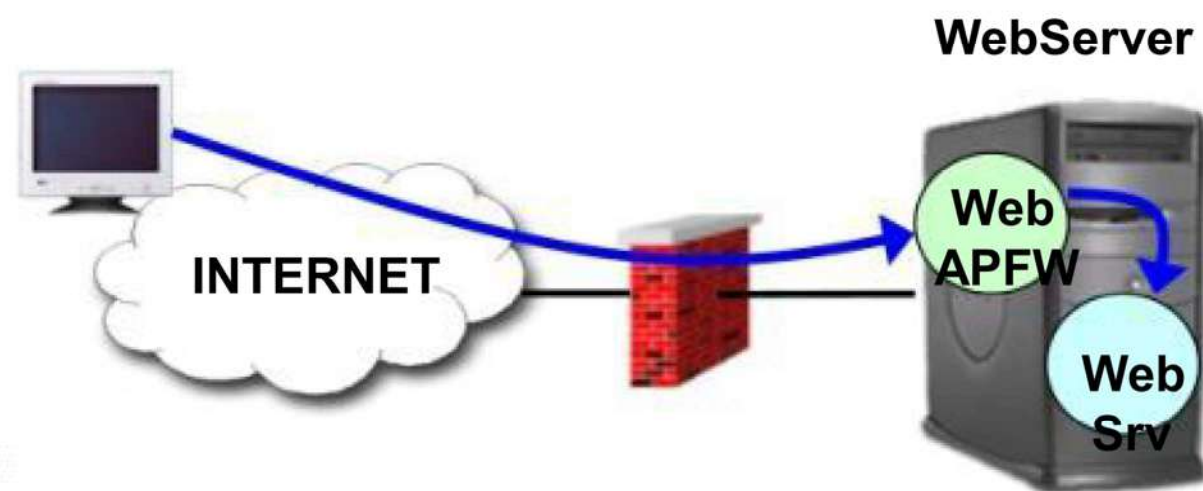
- ◆ 白名單(自動學習)，只有列在白名單的網頁與參數才能通過，其他一律拒絕。
- ◆ 攻擊特徵判斷是目前較常用的作法，但會有誤判與漏判的問題。

網站應用程式防火牆-類型與部署方式

—硬體式



—軟體式



網站應用程式防火牆

管理重點

- ◆ 存取規則的變更應建立管理程序(變更申請、核准及記錄)
- ◆ 異常的網站應用程式攻擊事件應立即匯出，並保留足夠的時間
- ◆ 異常的網站應用程式攻擊事件應定期分析，並進行異常的處理

選購時之重要規格

- ◆ 處理效能應符合組織網站流量需求
- ◆ 中文 URL 及傳輸內容的判斷能力
- ◆ HTTPS 的加密連線可先在網站應用程式防火牆解密過濾後，再轉到後端真正的網站(IDS/IPS無法判斷 HTTPS 連線)

其他相關的防護方法

- ◆ 由於網路入侵的管道很多，防禦上要盡量防堵各種可能的入侵途徑，最好在機構網路的實體入口就能有過濾與阻擋的機制，一直到最後的主機與系統的層次，也有偵測的功能。
- ◆ 可以採用垃圾郵件的過濾系統，設定寄件人黑名單，或是透過關鍵字比對、內容過濾條件等技術阻擋。
- ◆ 網站應用程式防火牆(WAF)可以偵測並防止針對網站應用程式的攻擊。
- ◆ 導入端點安全(end-point security)的技術，對更精密的攻擊方式產生圍堵的效果。
- ◆ 主機系統的更新與修補應該要隨時進行，並維持安全的設定，做好基本的防護工作。

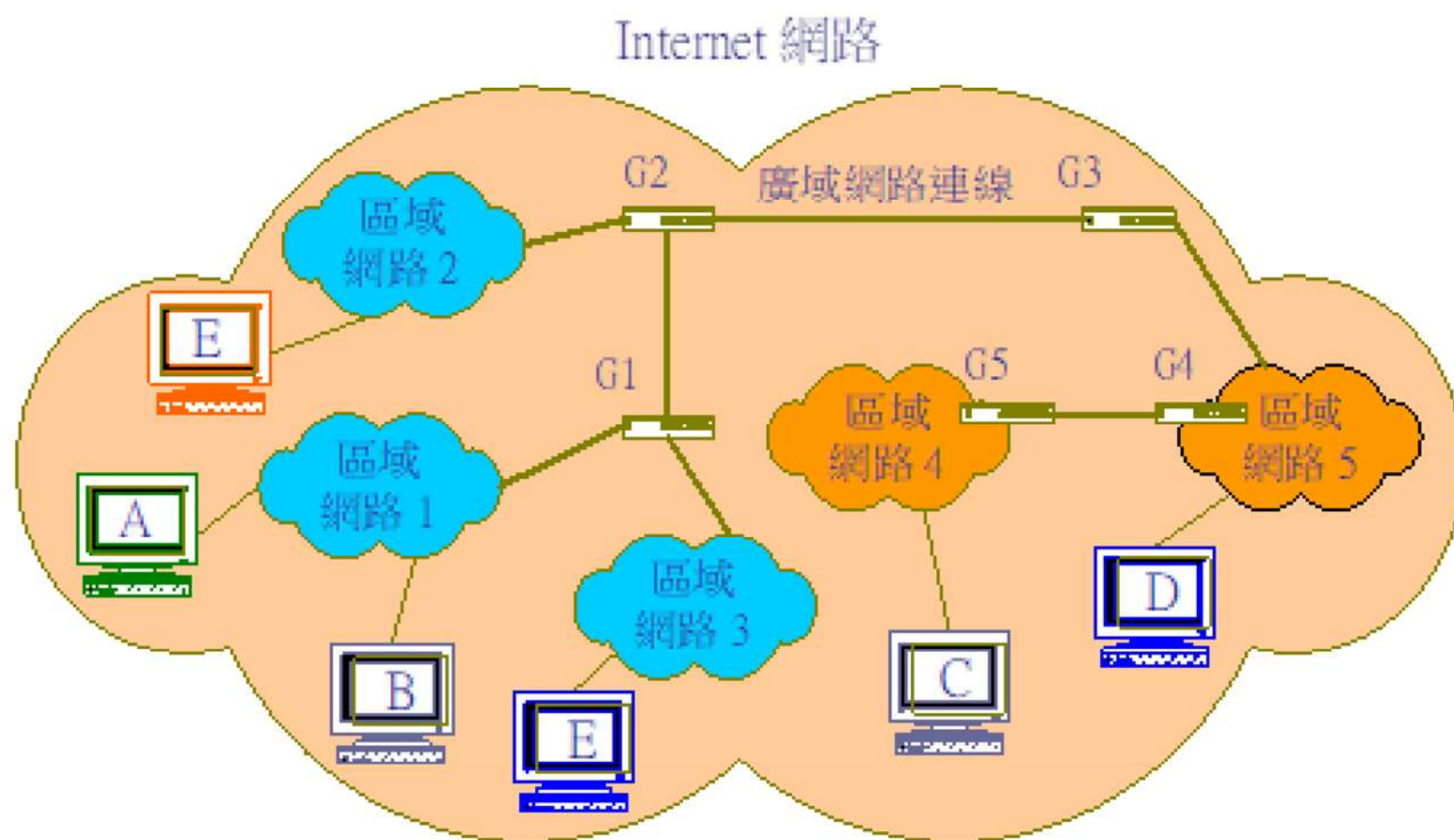
網路安全部署與組態

- ◆ 對於駭客來說，在發動攻擊以前都會先找目標，假如機構的網路漏洞百出，很容易就會成為被鎖定的目標。
- ◆ 機構的網路架構與設備：
 - 機構會有跟 ISP 租用的線路，加上 ISP 提供的設備，連上 WAN 線路負載平衡的設備，再接上外部防火牆，然後連上主要的核心交換器，後頭才會看到機構內部的網路。
 - 對外線路整合後有負載平衡與備援的效果，核心交換器是網路架構的樞紐，必須有很高的可靠性，持續維持運作，邊際交換器連接電腦與主機之後都會再連接核心交換器。

畫分網路區域

- ◆ 外網對內部須經過防火牆，沒有核准的服務與連線來源不能連接其他區域。DMZ 通常用來放置對外服務的伺服器只開放特定服務，須嚴格管控 DMZ 到內網之間的存取，實體隔離實體上不連接網路，網管區域放置網管設備，另外也可考量區分出放置備份與系統紀錄設備的區域。

- 對外的網路區域
- 對內的網路區域
- 非軍事區域(DMZ)
- 網路管理區域
- 實體隔離區域



無線網路安全

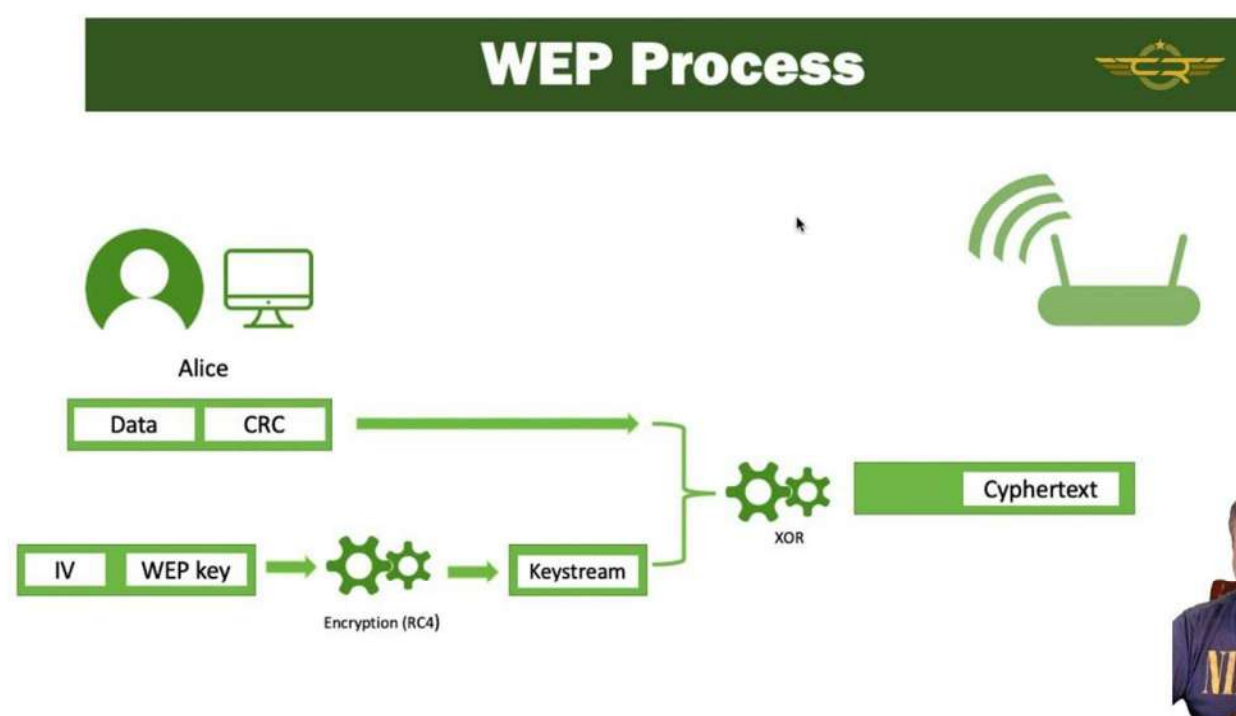
- ◆ 行動裝置的使用有其特殊的安全問題，而行動裝置進行無線通訊時同樣有網路安全的問題。

以資料的保護來說，最直接的解決方式是加密的協定與方法。



WEP(Wired Equivalent Privacy)

- ◆ WEP 是 IEEE802.11 WLAN 使用的安全協定，提供的功能包括資料加密與資料完整性的檢查，資料封包的加密使用 40 位元的方式，安全性不高，由於 WEP 在加密與安全協定上有一些缺陷，後來發展的 WEP2 使用 128 位元的加密方式。
- ◆ WEP 以密碼學(cryptography)為基礎，使用 RC4 cipher，屬於一種對稱式私鑰的串流加密法。
- ◆ WEP 原設計者指定使用的 RC4 是廣為接受的密碼加密法，但對攻擊者來說，不需要完全破解加密的演算法。
- ◆ 只要針對加密系統的弱點來發動攻擊，一樣能達到目標。各種破解 WEP 的方式採取的攻擊角度都不同。
- ◆ WEP 在設計上的缺陷，所發現的問題並不在於破解 RC4。



WPA(Wi-Fi Protected Access)

- ◆ 是替代 WEP 的一種解決辦法，實現了 IEEE802.11i 所訂定的大部分的規格，WPA 由 Wi-Fi 聯盟(即 Wi-Fi Alliance) 所制定，WPA 標準的運用與檢驗從 2003 年 4 月就開始，相關的IEEE802.11i標準則是到 2004 年 6 月正式通過。
Wi-Fi Alliance 在 2018 年發表了 WPA3。
- ◆ WPA 將資料以 128 位元的金鑰與的 48 位元初始向量(initialization vector) 以RC4 stream cipher 進行加密。
- ◆ WPA 與 WEP 的主要差異在於 TKIP(Temporal Key Integrity Protocol) 的使用，可以動態地改變金鑰。
- ◆ WPA2 持續改善WPA的功能，以AES(Advanced Encryption Standard) 取代 RC4。
- ◆ KRACK(Key Reinstallation Attack) 是針對 WPA2 的攻擊，利用協定的漏洞。



Q&A

作業系統與應用程式安全

作業系統安全

作業系統與應用程式(含資料庫與網頁)攻擊手法

程式與開發安全

常見應用程式的威脅

◆ 緩衝區溢位(Bufferoverflow)

◆ 惡意程式碼(Malware)

◆ 輸入攻擊

◆ 後門程式

◆ 邏輯炸彈

◆ 行動應用(App)的攻擊

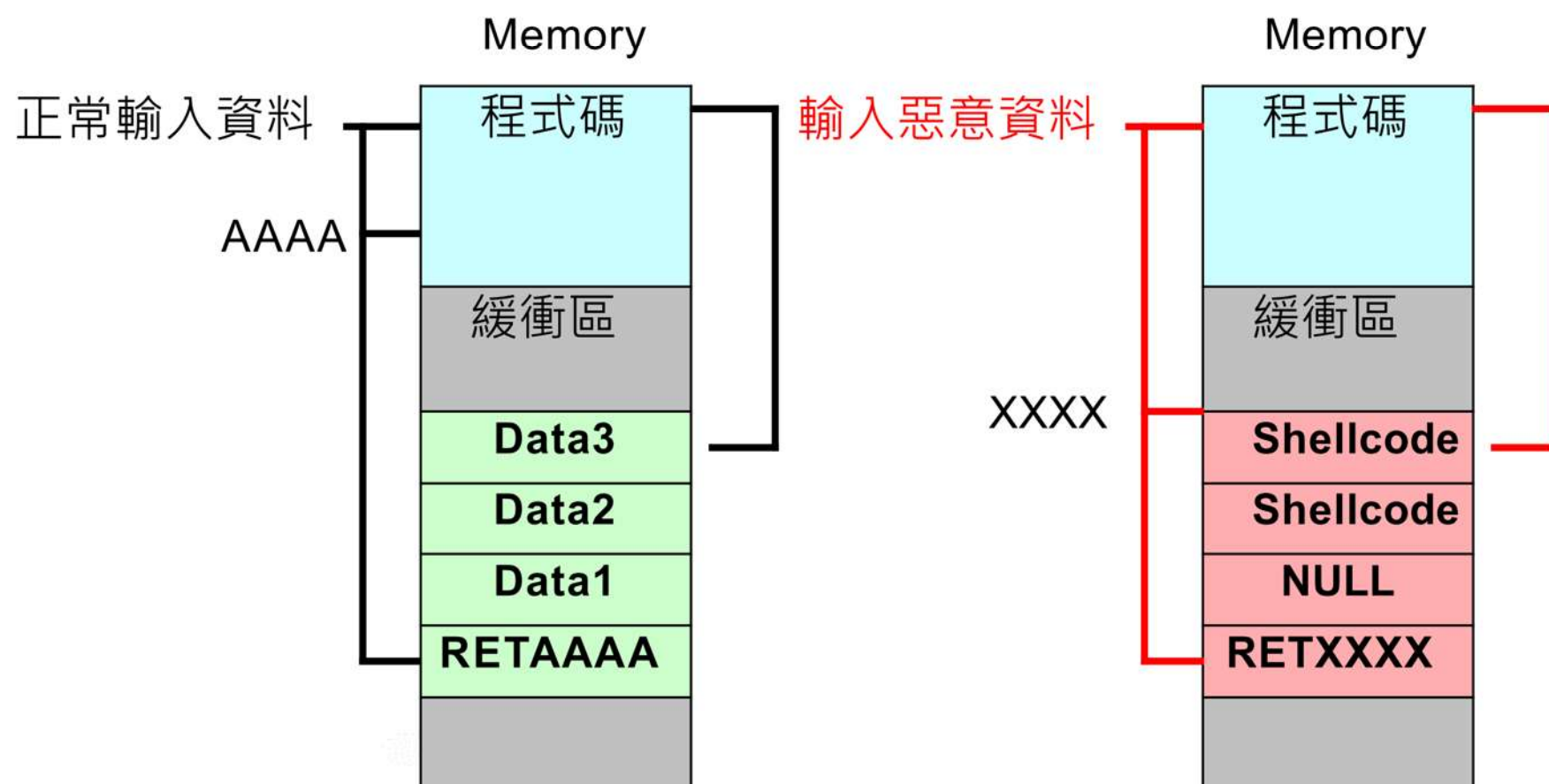
◆ 社交軟體的攻擊

◆ 記憶體洩漏(Memoryleaking)



常見應用程式的威脅 - 緩衝區溢位(Bufferoverflow)

- ◆ 緩衝區是程式執行期間在記憶體中用來存放資料的空間。
- ◆ 當應用程式處理資料時未檢查輸入資料的長度，就有可能讓太長的資料覆蓋到其他記憶體區段，導致惡意程式碼被植入而且被執行。



常見應用程式的威脅 - 惡意程式碼

- ◆ 惡意程式碼可分為病毒、蠕蟲、後門、木馬及間諜程式，這些惡意程式碼可能會附著在應用程式中，也可能獨立存在，導致程式執行效能變差與資料被竊。
 - **病毒**：需被動依賴寄宿的應用程式重製自己或感染其他程式。
 - **蠕蟲**：自己有能力主動進行傳染散播的惡意程式。
 - **後門**：留在系統內不需經一般安全控管程序，就可以被植入者遙控的惡意程式。
 - **木馬**：是一個陷阱程式，等待使用者踩到陷阱程式後，運用使用者權限執行不當的指令。
 - **間諜程式**：主要以竊取系統的機密資料為主的程式、例如：上網行為與鍵盤側錄等。
- ◆ 現今的惡意程式不見得只單純扮演一種角色，可結合各種不同的手法與行為感染與散播。例如：USB 病毒在 USB 硬碟時，運用病毒被動感染的方式感染電腦主機，一旦感染電腦主機後可能變成主動感染其他系統的蠕蟲。

常見應用程式的威脅 - 後門程式

- ◆ 留在系統內不需經一般安全控管程序，就可以被植入者遙控的惡意程式。
- ◆ 維護用後門程式：
 - 開發人員私下留存在應用程式內，以方便日後進行維護的程式。
 - 應用程式於整合測試階段，應檢查應用程式中是否含有後門程式。
- ◆ 被惡意植入的後門程式：
 - 由於應用程式其他的弱點(如：CommandInjection)，導致惡意後門程式被植入應用系統中。
 - 應用程式清單應被妥善維護，以區別非授權程式，也可以善用檔案的完整性檢查工具。

常見應用程式的威脅 - 邏輯炸彈

- ◆ 邏輯炸彈是一段被故意插入應用程式的程式片段，在正常情況下並不會被執行。只有當特定條件符合時才會被啟動。

例如程式設計師隱藏了一段刪除薪資資料庫的程式碼，只有當他被解僱的條件符合時才會被執行。

- ◆ 有些病毒與蠕蟲也會具有邏輯炸彈的程式碼—例如：當 4 月 1 日愚人節時將硬碟刪除。
- ◆ 應用程式於整合測試階段，應檢查應用程式中是否含有邏輯炸彈。

使用 SSL 就可以確保網站安全？

◆對於 SSL 的錯誤解讀

- 網站使用 SSL 加密，不怕資料外洩
- 我們的 SSL 用了強固式加密，所以很安全

◆事實上，使用 SSL 並不等於作好網站應用程式安全

- SSL 僅限傳輸過程的私密性保護，並不代表資料儲存時的私密保護
- 網站應用程式安全與資料傳輸的安全，為不同領域的問題
- 資料加密的連線內容，防火牆/IDS/IPS 是看不懂的
- 無法避免當駭客偽裝成使用者時在 SSL 連線中進行攻擊

已上線網站應用程式安全的防護

- ◆ 定期針對作業系統、網站伺服器及資料庫伺服器執行弱點掃描與修補。
- ◆ 定期執行網站應用程式弱點掃描滲透測試：
 - 黑箱：不知軟體結構，直接驗證功能。
 - 白箱：取得較多訊息。
- ◆ 有能力修改程式–修補已發現的應用程式弱點。
- ◆ 無能力修改程式–建置Web應用程式防火牆進行弱點防禦或其他補償措施。
- ◆ 新開發的應用程式可參考「安全軟體開發生命週期(SSDLC)」。

常見 Port

		port
檔案傳輸	FileTransferProtocol , FTP	21
安全遠端登錄	SecureShell , SSH	22
遠端登錄	Telnet	23
簡單郵件傳輸	SimpleMailTransferProtocol , SMTP	25
網域名稱服務	DomainNameService , DNS	53
超文本傳輸	HyperTextTransportProtocol , http	80
郵件接收	PostOfficeProtocolVersion3 , POP3	110
網路時間	NetworkTimeProtocol , NTP	123
安全超文本傳輸	HypertextTransferProtocolSecure , https	443

組態變更管理

- ◆ 企業必須對於系統的設定變更制定政策與程序，包括設施中變更要如何進行、誰能進行變更、變更如何核准、變更如何通報、以及變更如何記載。
- ◆ 組態變更管理(configuration management)：廣義來說，組態(configuration)代表一個系統運作時的可調整特性或是狀態。在系統存在運作的生命週期中，可能會為了讓系統的功能充分發揮而需要變更組態，但是組態的變更影響重大，要有適當的管理機制。
- ◆ 當資訊系統的組態變更時，要考量可能產生的影響，例如對於存取控制、可用性或是安全的影響。
- ◆ 組態變更若是可能對系統的正常運作產生影響，應考量影響的程度與範圍，以及變更前是否要測試。
- ◆ 安全組態變更前應進行風險評估，例如密碼的長度要求改變，應該考量是否被破解的機率提高。
- ◆ 存取控制的組態改變也會影響安全，例如防火牆的規則，應在變更前進行風險分析並取得核准。

變更控制

- ◆ 應用程式上線後因需求的變更、新功能要求及發現新瑕疵等因素，需要變更應用系統程式或組態。
- ◆ 目的：為維持變更後的安全狀態仍可符合安全政策要求。
- ◆ 方法：
 - 組織應實作應用程式變更控制流程。
 - 必須確保變更是獲得授權、經過測試且被記錄下來的。

變更控制

變更控制流程必要的步驟

- ◆ 填寫變更需求申請
- ◆ 分析變更需求
- ◆ 發展實作策略、方法或步驟
- ◆ 計算變更所需成本
- ◆ 評估變更與安全的關聯性
- ◆ 記錄變更請求
- ◆ 提交變更申請進行核准
- ◆ 進行應用程式變更的開發工作
- ◆ 記錄變更開發的產出(新增或删除功能)
- ◆ 將變更的程式碼與變更申請連結(程式碼中的註解)-將變更後的程式碼交付測試與品質認可
- ◆ 變更程式碼版本(上線)
- ◆ 向管理階層報告變更結果



職責區隔

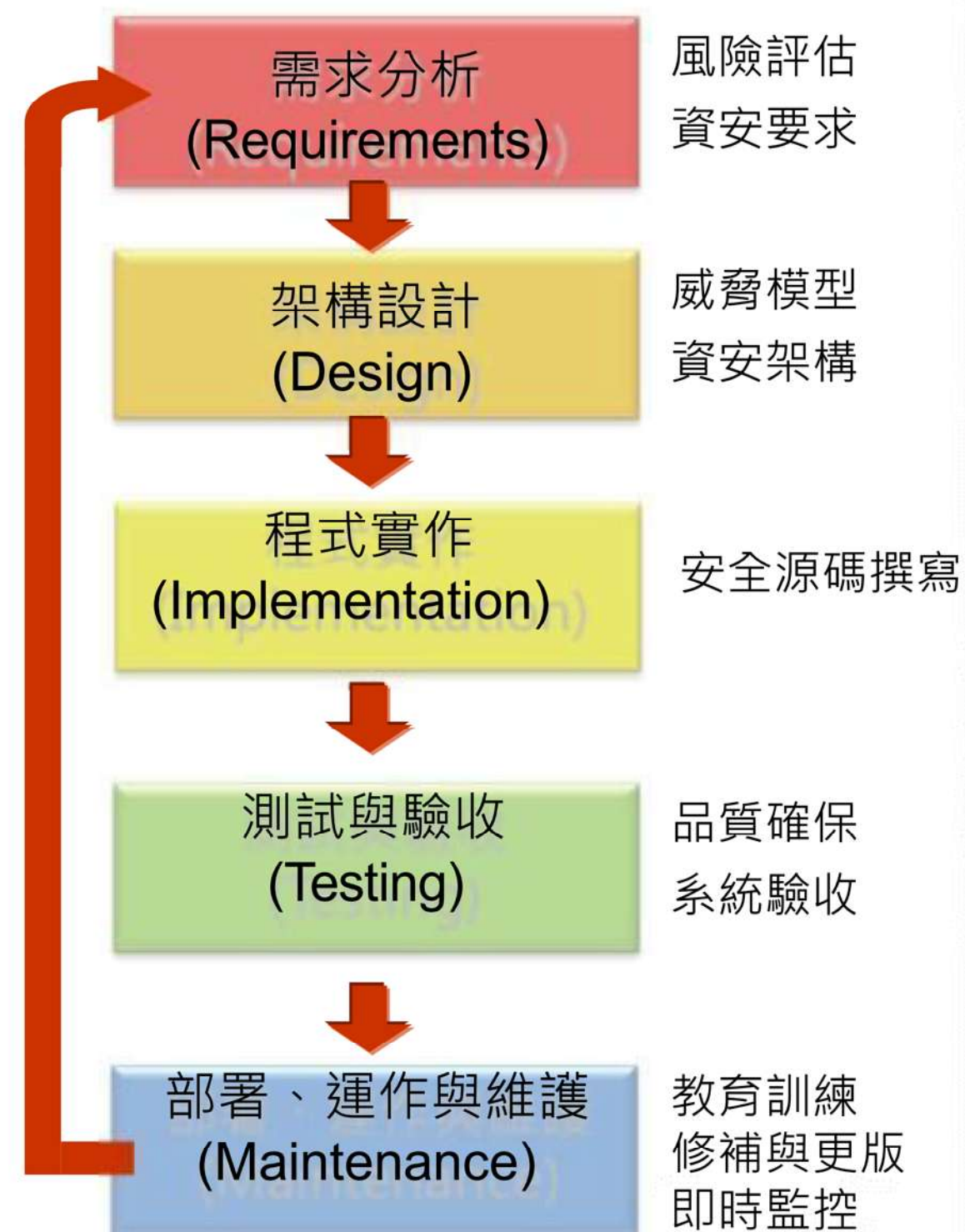
- ◆ 作業人員不應有權限存取線上的程式碼或程式物件。
- ◆ 程式設計人員不應存取線上運作中的軟體。
- ◆ 品管部門應測試程式碼品質，且與開發部門採用不同的測試方法。
- ◆ 一旦軟體被開發測試完成應被保存在程式庫中。
- ◆ 線上運作的軟體應由程式庫中發行，不應直接由程式設計人員或測試人員進行更新。

程式庫維護

- ◆ 應用程式應集中存放在程式庫中，並進行存取控管。
- ◆ 程式庫進行版本控制，並保留所有版本程式碼。
 - 主版本：1.0
 - 次版本：1.1
 - 緊急修正版本：1.0.1
- ◆ 開發部門凍結版本後應簽入(CheckIn)到程式庫，也應由程式庫中簽出(CheckOut)取得最新版本進行修改。
- ◆ 測試部門應由程式庫中簽出(CheckOut)取得最新版本進行測試。
- ◆ 上線人員應由程式庫中發行(Release)最新版本應用程式至線上系統。

安全軟體開發生命週期簡介

- ◆ 安全的軟體開發生命週期(Secure Software Development Life Cycle, SSDLC)意指發展一套安全的軟體之順序，如右圖所示。



安全軟體開發生命週期簡介

◆ 需求分析(Requirements)

著重資安需求定義，以符合使用者需求與法規遵循為目的

◆ 架構設計(Design)

根據需求分析結果，進行包含系統任務的目標、功能關聯、邊界範圍及各階層使用者的角色等內外部使用的規劃與搭配適當的資安架構

◆ 程式實作(Implementation)

落實既有之規劃，將使用者介面、功能運作及安全性等完整的實現

◆ 測試與驗收(Testing)

進行運作模擬，檢驗該系統的完成度，確保各項功能與安全性皆可符合既定的需求

◆ 部署與維運(Maintenance)

進行軟體之部署，安排教育訓練—落實軟體之穩定運作，應定期修補漏洞(Patch)、按步升級更新版本(Upgrade)及即時監控(Monitor)

安全軟體開發生命週期

- ◆ 開發廣泛應用銷售普遍的軟體，假如出了資安上的問題，影響的層面會很大，最好在軟體開發的時候就先考量到資安的問題，避免可能存在的弱點或是漏洞。
- ◆ 安全軟體發展流程：為了維持資訊安全，軟體系統的開發應導入安全軟體開發生命週期，政府機關在開發軟體系統時，已被要求採用安全軟體發展流程(SSDLC，Secure Software Development Life Cycle)
- ◆ 一般的機構也可以採用 SSDLC 來確保自己或是委外開發的軟體系統滿足資安的要求。
- ◆ 傳統的軟體發展流程以功能的開發為主，沒有同時考量安全的問題。
- ◆ 安全軟體發展流程須在軟體開發時也一起考量資安，會加長開發時程，但能降低維護成本與被攻擊的風險。
- ◆ OWASP 發展的 CLASP(Comprehensive，Lightweight Application Security Process)計畫把資安運用在軟體開發的流程中。

安全軟體開發的流程

◆ 安全軟體開發的流程也有國際標準，ISO/IEC27034:2011提供了軟體開發安全的流程與框架，為軟體開發商樹立實作的指引。

另外也可以參考美國的 NISTSP800-64，看如何將安全的需求整合到軟體系統發展的生命週期。



安全軟體設計

- ◆ 假如本身的工作是在軟體開發的部門，一定要建議機構導入安全軟體設計，要導入就必須了解相關的標準、方法論與實務，美國的國家弱點資料庫(NVD，National Vulnerability Database)的統計資料顯示93%的弱點是應用程式層面的弱點。
- ◆ 一般的軟體系統開發都把重要放在功能面的達成，忽略了軟體本身的安全問題。
- ◆ 在設計階段運用安全軟體設計的方法可以提高軟體品質，所以最好在設計階段先顧好資訊安全的問題。
- ◆ 在設計階段排除問題的成本只有維護階段的百分之一，這是IBM Systems Sciences Institute的研究結果。
- ◆ 微軟公司在西元 2004 年就開始發展SDL(Security Development Life cycle)，是一種軟體開發的安全發展生命週期。



安全軟體測試

- ◆ 不管是自行開發或是委外，都有需要進行安全軟體測試，以確保所開發的軟體系統的安全無虞。跟安全軟體測試相關的國際標準包括IEEE829:2008、ISO/IEC/IEEE29119:2013與 OWASP Testing Guide等。
- ◆ 軟體的安全其實也可以看成是我們對軟體系統所要求的功能之一，算是一種需求。
- ◆ 在軟體發展的需求分析階段，就應該先把安全方面的需求訂清楚，變成安全測試進行時的依據。
- ◆ NIST 研究指出若之前未發現，而在軟體開始使用後才進行修補，花費的成本是發展時修補成本的30倍以上。
- ◆ 除了要知道有哪些工具可用、如何使用之外，還要能解讀測試工具產生的報告，並且能規劃出應對的方案。

安全需求驗證

- 測試軟體中與安全相關的功能

安全性測試

- 從攻擊面思考軟體的防禦能力，偏重找出軟體的錯誤與缺陷

資訊委外安全

- ◆ 不管是一般組織或是政府機構，都有可能把資訊業務委外，這和資訊業務完全由組織內部人員完成是不同的，必須要有資訊委外安全的管理。
- ◆ 資訊作業委外的定義：將機構的部分或全部的資訊系統功能、資訊相關活動，轉交給外部的資訊服務提供者來完成。
所指的資訊系統功能與活動涵蓋資訊軟硬體、資訊設施與資訊服務等，軟體系統也常見委外開發的情況。

委外作業的型態

- ◆ 政府機關對於委外作業通常都有詳盡的規定，讓公務人員有遵循的原則，以政府委外的資訊服務來說，一般是指提供與電腦軟硬體相關的服務，為了委外作業的方便，將資訊委外分成不同的型態，一般私人機構也可參考使用。
- ◆ 包括整體規劃、系統整合、系統稽核、系統管理、網路管理、軟體開發、軟體驗證、軟體維護、硬體維護、硬體操作、機房設施管理、備援服務、網路服務、顧問諮詢、資料庫建置、資料處理、資料登錄或訓練推廣等服務都算。



顧問訓練



系統發展



維運管理



雲端服務

委外服務的資安策略

- ◆ 組織辦理資訊委外服務的業務時，應訂定委外相關的策略，需包括資訊委外業務的原則、委外服務的策略，以及委外服務的資安策略。當發生違反法令或是發生資安事件時，須立即通知委託機構。
- ◆ 在原則上應考量廠商的專業、委外項目的性質與資安要求，選擇適當的廠商，並監督其作業。
- ◆ 委外廠商應具有適當的資訊管理措施或是通過第三方驗證，並有資安方面的專業人員。
- ◆ 委託關係終止時，須要求廠商歸還、移交、刪除或銷毀履約時所取得持有的資料。
- ◆ 以政府機關為例，有關個資的境外傳輸是採取「**原則禁止，例外允許**」，歐盟地區需遵循 GDPR 的要求。

委外作業的實務

◆ 委外廠商常因為各種因素，需要對機構的系統進行操作，對於機構來說，必須考量一些潛在的風險，例如廠商的電腦有可能已經被駭，此時應有一台機構特別準備的電腦專供委外廠商遠端連線之用，除了有適當的保護與限制之外，也對廠商的操作進行側錄，可做為未來稽核或是事件處理之用。

◆ 委外生命週期

01 決定需求	02 評估方案	03 選定方案	04 完成建置	05 正常營運	06 順利結案
初始(initiation) 明訂資訊系統的需求，並識別資安的需求，考量資安風險，以降低風險為原則	評估 考量資訊環境的現況，以及預期達到的目標，找出可行的解決方案，方案應涵蓋資訊安全的解決方式	解決方案 從評估階段得到的解決方案中進行選擇，選擇委外廠商之後須完成合約的簽訂，以及人員保密協定的簽認	建置 與委外廠商協力進行建置的工作，在建置過程中應依照合約與資安管理的要求進行監督與稽核	營運 完成建置開始運作以後，應針對服務水準與資安的作為進行檢討，必要時進行階段2~階段5的循環改善	結束 委外結案，須確認廠商配合完成資安要求的結案流程。若未來有需求的變更，可再循此循環進行更新

各項業務委外的風險

- ◆ 大多數的委外風險是因為沒有把安全的需求完整地放入合約中，或是雖有納入合約，但在實務上沒有確實監督廠商是否有遵循合約的規定。例如對於廠商處理的個資範圍未清楚約定，在廠商歇業時無法取回委外處理的資料。
- ◆ 應訂定委外策略，例如避免過度倚賴特定或少數廠商，在管理方面應建立適當的管理模式與程序。
- ◆ 對需求規劃的描述要貼近實際的需求，特別是維運時的服務要求與資安要求，應該清楚說明。
- ◆ 委外的關係首重合約的描述，合約不完整、缺少合約終止規範，或是缺乏細節，都會產生風險。
- ◆ 未能選擇適合的廠商會形成很大的風險，不僅廠商無法提供所需要的服務，還會產生一些連帶的問題。

委外作業的資安要求

- ◆ 資訊業務委外的原因很多，一旦決策確定，就應該在資訊委外的生命週期中做好資安的要求。委外作業勢必會讓機構部分的資訊設施與資源暴露在委外廠商的執行範圍下，不僅機構本身要按照資安管理程序執行控管，廠商也要有資安管理的基本能力。
- ◆ 委外作業的資安要求可以分成不同的階段來考量，包括規劃、招商、履約管理、驗收、保固與爭議處理。
- ◆ 委外作業的規劃從建議書徵求文件(RFP)開始，廠商應針對 RFP 提出其做法，應仔細評估。
- ◆ 廠商的專業資格應有限制，例如對於委託領域的專業，由於是資訊業務委外，應特別要求資安的專業。
- ◆ 對於風險評鑑後的高風險項目，應提出資安技術面的需求，依各種委外型態在 RFP 中明訂資安需求。

委外管理重點

- ◆ **委外實體與環境安全**：防止組織場所內資訊因委外作業而遭未經授權的實體存取、損害及干擾，關鍵或敏感的資訊處理設施宜置放於安全區域。
- ◆ **委外之作業管理**：委外相關作業應符合組織安全政策與程序之要求。
- ◆ **委外使用者存取管理**：組織宜有正式程序，以控制資訊系統與服務的存取權限配置作業。
- ◆ **委外資訊安全事故管理**：委外組織宜備妥正式的事故通報與提報程序，提供委外作業廠商配合並施予合宜訓練。
- ◆ **遵循適法性要求**：組織於資訊系統設計、運作、使用及管理都應受法律、法令、法規或契約的安全要求所規範，所參照之規範宜明確界定、文件化及維持最新版本。

驗收與維護

- ◆ 組織執行「驗收階段」程序，係依據契約文件與「履約管理」階段執行成果辦理。
- ◆ 以「專案工作計畫書」內容確認委外專案之進行方式、專案組織、相關時程及資訊安全要求事項是否符合。
- ◆ 而委外廠商也須將定期召開工作進度報告會議之內容，如應完成重要工作項目、已完成工作的項目、預計工作項目、問題與建議等，提供驗收單位佐證。
- ◆ 定期審查廠商成效。

爭議處理

◆組織與廠商因履約管理產生爭議未能達成協議者，得以下列方式之一處理：

- 向採購申訴審議委員會申請調解
- 向仲裁機構提付仲裁

◆若雙方於問題標準界定上有所爭議時

- 可蒐集發生的事證與相關資訊
- 尋求具公信力之第三者、學者專家、法院或調解委員會(如行政院公共工程委員會)等
- 進行問題的釐清與相關問題的調解

Q&A